

정보보안 기본규칙

제 정 : 2018. 1. 11.
제 1차 개정 : 2023. 6. 1.
제 2차 개정 : 2023. 12. 11.
제 3차 개정 : 2025. 06. 01.
제 4차 개정 : 2026. 07. 01.

제1장 총칙

제1조 (목적) 본 규칙은 「고용노동부 보안업무규정 시행세칙」에 의거 한국기술교육대학교 (이하 "본교" 라 한다)의 정보보안활동에 필요한 세부사항 규정을 목적으로 한다.

제2조 (적용범위) 본 지침은 본교 내 전체 정보시스템 및 PC, 대학 구성원에게 적용한다.

제3조 (용어 정의) 이 규칙에서 사용하는 용어의 정의는 다음과 같다.

1. “정보통신망”이라 함은 유·무선을 매개로 하는 다양한 정보통신수단에 의하여 부호, 문자, 음향, 영상 등의 정보를 수집·가공·저장·검색·송수신하는 정보 통신체계를 말한다.
2. “정보보호”또는“정보보안”이라 함은 정보통신수단으로 수집·가공·저장·검색·송수신되는 정보의 유출·위변조·훼손 등을 방지하거나 정보통신망을 보호하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위를 말한다.
3. “전산장비실”이라 함은 서버·PC등 전산장비와 스위치·교환기·라우터 등 통신 및 전송장비 등이 설치 운용되는 장소를 말한다.
4. “전산자료”,“전자문서”,“전자기록물”이라 함은 전산장비에 의하여 전자기적인 형태로 입력·보관되어 있는 각종 정보(data)를 말하며, 그 자료가 입력되어 있는 자기테이프, 디스크 등 보조기억매체를 포함한다.
5. “보조기억매체”라 함은 디스켓·CD·하드디스크·USB 메모리 등 정보를 저장할수 있는 것으로 정보통신시스템과 분리할 수 있는 기억장치를 말한다.
6. “정보보안시스템”이라 함은 정보의 수집·저장·검색·송신·수신시 정보의 유출, 위·

변조, 훼손 등을 방지하기 위한 하드웨어 및 소프트웨어를 말한다.

7. “비밀번호”라 함은 전산장비에 저장되어 있는 자료를 무단열람하거나 부정출력하지 못하게 하기 위하여 사용하는 패스워드를 말한다.
8. “기밀성”이라 함은 정보가 인가되지 않은 개인이나, 처리과정 등에 누설되거나 공개되지 않는 속성을 말한다.
9. “무결성”이라 함은 정보가 고의적 또는 우발적으로 변경, 파괴되지 않고 일관성을 유지하는 속성을 말한다.
10. “가용성”이라 함은 인가자가 정보나 정보시스템을 사용 또는 접근하고자 할 때 사용 또는 접근이 가능하게 하는 속성을 말한다.
11. “접근통제”라 함은 인가된 사용자, 프로그램, 프로세스, 시스템 등의 주체만이 정보시스템의 자원에 접근할 수 있도록 제한하는 것을 말한다.
12. “중요정보”라 함은 노출, 변경, 파괴되면 본교에 지대한 영향을 미칠 수 있는 정보를 말한다.
13. “로그”라 함은 시스템 사용에 관련된 전체의 기록, 즉 입출력 내용, 프로그램 사용 내용, 데이터 변경 내용, 시작시간, 종료시간 등의 기록을 말한다.
14. “프로젝트담당자”라 함은 정보시스템 개발 등의 외부용역사업 시 본교의 해당 업무담당자를 말하며, 해당 용역사업 및 용역업체 직원에 대한 관리 책임이 있다.
15. “내부망”이라 함은 본교의 보안관리하에 있는 네트워크 중 침입차단시스템 또는 스크리닝 라우터를 경계선으로 하여 보호받는 본교의 주요 네트워크를 말한다.
16. “외부망” 또는 “상용망”이라 함은 내부망을 제외한 모든 네트워크를 말한다.
17. “단말기”라 함은 시스템에 연결되어 단순히 입·출력 기능만 수행하는 전용단말기와 내부망에 연계되어 운용하고 있는 개인용 컴퓨터를 포함한다.
18. “RFID(Radio Frequency IDentification) 시스템”이란 대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용, 해당 사물 등의 식별정보 및 주변 환경정보를 인식하여 각 사물 등의 정보를 수집·저장·가공 및 활용하는 시스템을 말한다.
19. “개인정보”라 함은 생존하는 개인에 관한 정보로서 당해 정보에 포함되어 있는 성명·주민등록번호 등의 사항에 의하여 당해 개인을 식별할 수 있는 정보(당해 정보만으로는 특정개인을 식별할 수 없더라도 다른 정보와 용이하게 결합하여 식별할 수 있는 것을 포함한다)를 말한다.
20. “내부감사”라 함은 정보보호 관련 지침과 매뉴얼의 준수 여부를 확인하고, 개선사항을 제시하며 이행을 권고하는 활동을 말한다.
21. “침해사고”라 함은 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스 거부 또는 고출력 전자기파 등에 의하여 정보통신망 또는 이와 관련된 정보시스템을 공격하는 행위로 인하여 발생한 사태를 말한다.
22. “행정지역”이라 함은 학생 및 대학원생이 사용하는 실습실 및 연구실을 제외한 학사 운

영 및 대학 운영등과 관련된 부서 및 장소를 말한다.

23. “클라우드”라 함은 집적·공유된 정보통신기기, 정보통신설비, 소프트웨어 등 정보통신 자원을 이용자의 요구나 수요 변화에 따라 정보통신망을 통하여 신축적으로 이용할 수 있도록 하는 정보처리체계를 말한다.

제2장 정보보안 조직 체계

제4조 (정보보안심사위원회) ①정보보안 업무에 관한 중요한 사항을 심의·의결하기 위한 정보보안심사위원회(이하 ‘심사위원회’)는 전산정보의 관리 및 서비스에 관한 규칙 제2장 정보화위원회를 준용한다.

②심사위원회는 다음 각 호의 사항을 심의·의결한다.

1. 정보보호 지침 제·개정에 관한 사항
2. 정보보호 활동 평가 및 위험관리계획 수립에 관한 사항
3. 기타 정보보호책임관이 정보보안과 관련하여 필요하다고 인정하는 사항

제5조 (정보보안 조직 구성) ①본교 정보보안 업무를 원활히 수행하기 위하여 정보보안 조직을 구성한다.

②정보보안 조직의 구성은 다음과 같다.

1. 보안담당관은 보안업무 처리규칙 제9장 40조에 의해 규정된 총무팀장으로 한다.
 2. 정보보호책임관(CISO) : 학술정보원장
 3. 정보보호담당관(정보통신분임보안담당관) : 보안업무 처리규칙 제8장 제52조에 의해 규정된 정보화운영팀장으로 한다.
 4. 정보보호담당관은 정보보호책임관을 보좌하여 전반적 기술분야 정보보안업무를 수행한다.
 5. 분임정보보호담당관 : 각 부서의 팀장
 6. 분임정보보호담당관은 효과적인 정보보안 업무 수행을 위해 정보보호 및 개인정보보호 전문성과 다양한 서비스에 대한 이해도와 경험이 많은 소관부서의 직원을 정보보호담당자로 지정하여야 하며, 별도 지정이 없는 경우 서무가 ‘부서 정보보호담당자’가 된다.
- ③ 정보보호 및 개인정보보호 관련 사항에 대하여 실무 차원에서 공유·조정·검토·개선하고, 의사결정 및 경영진 지원이 필요한 경우에는 심사위원회에 상정하는 역할을 정기적으로 수행할 수 있는 정보보안 실무협의체를 개최한다. 정보보안 실무협의체는 정보보호담당관과 각 역할별 분임정보보호담당관으로 구성한다.

제6조 (정보보호책임관) 정보보호책임관은 대학의 정보보호 업무를 총괄하며, 다음 각호의

업무를 수행한다.

1. 정보보호 관리체계의 수립 및 관리·운영
2. 정보보호 지침 등 관련 정보보호문서 제개정 총괄
3. 정보보안 내외부 감사 및 점검 총괄(상위기관)
4. 주요 연간 기술분야 정보보안 활동계획 수립 및 이행
5. 주요 정보자산 목록에 대한 관리 및 통제
6. 침해사고 대응체계 수립 및 이행
7. 보안취약성, 위험 분석 및 보안대책 적용
8. 신규 정보시스템 개발 시 자체 보안대책 적용
9. 상위기관 보안성 심의 요청
10. 정보보안시스템 보안정책 등록 및 변경
11. 정보통신망 및 정보자료 등의 보안관리 주관
12. 정보통신망 신·증설시 보안대책 수립
13. 기타 정보보안업무 전반에 관한 지도, 조정 및 기타 감독에 관한 사항

제3장 정보보안 목표 및 기본활동

제7조 (기본목표) 한국기술교육대학교 정보보안의 기본목표는 본교가 보유하고 있는 중요 정보 유출을 방지하고 정보시스템 및 정보통신망의 기밀성·무결성·가용성을 확보하는 데 있다.

제8조 (활동방향) 본교는 정보보안을 위하여 다음 각 호의 기본활동을 수행한다.

1. 정보보안 정책 및 활동 세부계획 수립·시행
2. 정보보안 감사·지도점검 실시
3. 취약 정보통신망 보안대책 수립 추진
4. 정보보안 위규 적발 및 사고조사 처리
5. 사이버위협정보 수집·분석 및 보안관제
6. 사이버공격 관련 경보 발령 시 대응활동
7. 침해사고 대응·복구
8. 정보보안 교육계획 수립·시행
9. 정보보안업무 심사분석 시행
10. 정보보안 관련 규정·지침 등 제·개정
11. 기타 정보보안 관련 사항

제9조 (정보보안 추진계획 수립 및 검토) ①정보보호책임관 및 정보보호담당관은 연간 정보보안 추진계획을 수립·시행하고 그 추진결과를 심사·분석해야 한다.

②정보보호책임관 및 정보보호담당관은 세부추진계획 및 심사분석을 ‘[별지 제1호 서식] 정보보안업무 추진계획’ 및 ‘[별지 제2호 서식] 정보보안업무 심사분석’에 따라 작성하여 관리해야 한다. 필요한 경우 별도의 서식을 사용할 수 있다.

③또한 본 규칙을 비롯한 정보보호관련 문서에 대해 연간 1회 이상 본교가 준수하여야 하는 정보보호 및 개인정보보호 관련 법적 요구사항을 파악하여 문서에 반영하고 준수 여부를 검토하는 것을 원칙으로 하며 상위기관의 규칙 및 지침 등이 변경될 경우 최신의 보안정책을 반영하기 위해 상시 개정을 추진 할 수 있다.

④정보보호관련 문서에 대해 검토 시 본교가 준수하여야 하는 정보보호 및 개인정보보호 관련 법적 요구사항을 파악하여 문서에 반영하고 준수 여부를 검토하여야 한다.

⑤정보보안 추진계획 수립 시 정보보호 및 개인정보보호 관리체계 범위 전 영역에 대한 위험관리계획이 포함되어야 한다.

제10조 (위험분석) ①정보보호담당관은 연간 1회 이상 운영 중인 정보자산뿐만 아니라, 추가 도입되는 정보자산에 대해서도 위험분석을 실시할 수 있다.

②본교의 정보보안을 구성하는 환경의 중대한 변화가 발생했을 경우, 정보보호책임관의 결정에 따라 위험분석을 실시할 수 있다.

③정보보호담당관은 위험분석 및 평가 결과를 작성하여 경영진에게 보고하여야 한다.

제11조 (위험관리) ①정보보호담당관은 위험분석 결과를 바탕으로, ‘위험수용기준(DoA)’에 따라 관리대상 위험을 식별하고 각 부서의 위험분석 및 단계별 위험관리방안을 참고하여 ‘정보보호 대책명세서’를 작성할 수 있다.

②정보보호담당관은 작성된‘정보보호 대책명세서’의 이행여부를 확인하여 재발방지대책을 수립하고 개선 결과를 경영진에게 보고한다.

제12조 (내부감사) ①정보보호책임관, 정보보호담당관은 정보보안 전반에 대한 연간내부감사 계획을 수립하여 실시한다.

②정보보호담당관은 내부감사 결과 발견된 취약점 및 부적합 사항에 대해 각 해당 팀에게 적절한 조치를 취하도록 권고하며, 이의 이행을 모니터링 한다.

③감사대상 영역에 대한 보안감사 증적(Audit Trails)을 확보하고, 증거 자료의 무결성이 보장되도록 조치한다.

④서버, 네트워크시스템, 응용시스템, 데이터베이스 등에 대하여 내부감사에 필요한 시스템 로그의 종류와 보존기간을 해당 지침 및 매뉴얼에 명시하여, 심사 시에 충분한 증거로서 활용한다.

- ⑤내부감사 시 사용되는 정보시스템 감사도구에 대한 오용 및 손상을 방지하기 위한 적절한 통제를 수행하여야 한다.
- ⑥내부감사를 위해 필요한 경우 외부 지식정보보호 전문업체를 통하여 점검을 수행할 수 있다.

제4장 정보자산관리

제13조 (정보자산 식별 및 관리) ①정보보호담당관은 정보시스템과 관련된 정보자산들에 대해서는 총괄책임을 지고 분임정보보호담당관은 소관부서별로 정보자산관리자를 지정하여 해당 자산을 관리한다.

②정보보호담당관 및 분임정보보호담당관은 정보자산 식별 및 분류 작업을 수행하며 정보자산의 소유자, 관리자, 사용자 및 정보자산 보호등급을 정의하고 정보자산에 대한 목록 '[별지 제3호 서식]정보자산목록'을 관리하도록 한다.

③정보보호담당관은 중요도 평가 기준을 수립하여 평가 기준에 따라 정보자산에 대한 중요도를 평가한다.

④정보보호담당관은 정보시스템 운영 환경의 변화에 따라 자산의 중요도 평가 기준을 변경할 수 있다.

⑤정보보호담당관은 정보 자산의 도입, 추가 및 폐기로 인해 변경사항이 발생한 즉시 정보자산목록을 변경해야 한다.

⑥분임정보보호담당관은 소속부서의 정보자산현황을 작성하여 관리해야 하며, 해당 정보자산의 현황이 변경된 경우 소속부서의 정보자산 현황을 정보보호담당관에게 통보해야 한다.

⑦정보보호담당관은 중요 정보자산에 대하여 주기적으로 또는 용도 및 세부내역이 변경된 경우 중요도를 재검토하여 재분류 한다.

⑧정보자산 범위의 중대한 예외 사항이 발생할 경우, 해당 분임정보보호담당관은 명확한 사유 및 예외사항에 대해 보고하고 정보보호담당관의 승인을 득하여야 한다.

⑨정보보호담당관은 주기적으로 정보서비스 및 개인정보 처리 현황을 분석하고 업무 절차와 흐름을 파악하여야 한다.

제14조 (정보자산의 보안관리) ①본교 내부직원 및 외부 용역직원들은 본교 내부 정보자산을 개인의 목적으로 외부 반출 및 타인에게 전송 할 수 없다.

②전자적 형태의 정보자산을 업무상 목적으로 전송 또는 배포하고자 하는 경우에는 승인된 정보기기 및 전송망을 사용해야 한다.

③정보보호책임관은 중요 정보자산에 대하여 비인가자의 무단접근을 통제할 책임을 지닌

다.

④중요 정보자산의 외부 반출은 소속팀장의 사전 승인 후 반출한다.

1. 소속팀장은 감사를 위해 관련내용을 기록 관리하고, 저장매체 내의 데이터를 확인한다.
2. 소속팀장은 외부로 반출·입 되는 정보자산의 승인여부를 확인하고, 관련내용을 기록 관리한다.

⑤업무상 조직간 중요 정보 및 개인 정보를 상호 교환하는 경우, 안전한 전송을 위한 협약 또는 대책을 수립하고 이행해야 한다.

⑥정보보호책임관은 관련 규정에 따라 정보자산이 적절하게 사용 및 운용되고 있는지 관리·감독한다.

제 14조의2(시스템 보안책임 범위) ①사용자는 개인PC 등 소관 정보시스템을 사용하거나 본인 계정으로 정보통신망에 접속하는 것과 관련한 보안책임을 가진다.

②시스템관리자는 서버·네트워크 장비 등 부서 공통으로 사용하는 정보시스템의 운용과 관련한 보안책임을 가진다.

③제1항부터 제2항까지와 관련하여 정보시스템을 실제 운용하는 부서의 장이 정보시스템 ‘관리책임자’가 되며, 관리책임자는 정보시스템 관리대장을 수기 또는 전자적으로 운용 관리하여야 한다.

④관리책임자는 부서의 정보시스템 관리대장에 정보시스템의 변경 최종 현황을 유지하여야 하며, 사본1부를 정보보호담당관에게 제출해야 한다.

⑤정보보호담당관은 제1항부터 제4항까지에 명시된 정보시스템 운용과 관련한 보안대책 강구가 필요하다고 판단할 경우, 사용자·시스템관리자 및 관리책임자에게 시정을 요구할 수 있다.

제 15조 (정보자산의 폐기) ①교내 행정지역에서 정보자산의 폐기사유가 발생하면 정보보호담당관의 승인을 받은 후 폐기한다.

②정보자산 재사용 또는 폐기 시에는 다음 사항을 준수해야 한다.

구 분	출력물	보조기억매체
재사용	대외비 이상 정보의 재사용 (이면지 사용)금지	덮어쓰기 또는 신뢰할 수 있는 방법으로 데이터 완전 소거
폐 기	문서 수거함이나 문서 파쇄기를 통한 폐기	물리적으로 매체의 완전 파괴

제5장 정보보안 교육 및 홍보

- 제16조 (정보보안 교육 및 홍보)** ①정보보호책임관은 전 교직원을 대상으로 연 1회 이상 정보보안 교육을 실시하여야 한다.
- ②정보보호책임관은 정보보안 교육의 효율성, 전문성을 높이기 위해 외부전문가의 지원을 요청할 수 있다.
- ③정보보호책임관 및 정보보호담당관은 업무 전문성을 제고하기 위해 연 1회 이상 정보보안전문기관 교육 또는 정보보안 관련 세미나에 참석해야 한다.
- ④정보보호담당관은 교직원에게 정보보안 인식을 제고할 수 있는 다음과 같은 내용을 활용하여 전자메일(e-mail), 교내 게시판(홈페이지, 그룹웨어) 등을 활용하여 홍보활동을 주기적으로 수행 한다.
- ⑤교육 시행 후 결과를 기록하고, 평가 기준에 따라 설문 또는 테스트 등을 통해 교육 내용의 적절성과 효과성을 평가하여 추후 교육 계획에 반영한다.
- ⑥내부 규정 및 절차의 중대한 변경, 조직 내·외부 침해사고 발생, 관련 법규 변경 등 발생 시, 이에 대한 추가 교육을 수행해야 한다. 단, 사안이 중요하지 않을 경우 게시판 공지, 이메일 안내, 책자 배포 등으로 대체할 수 있다.

제6장 인적보안

- 제17조 (채용 시 보안)** ①교직원(계약직 포함) 채용 시에는 재직 중에 취득한 정보에 대한 보안을 유지하도록 '[별지 제4호 서식] 정보보안 서약서(교직원용)'를 징구해야 한다.
- ②정보보호담당관은 신규 입사자에 대해서 내부 보안업무 처리규칙, 정보보호 기본규칙, 개인정보보호규칙 등의 내용을 포함하여 정보보안 교육을 수행하고, 정보보호책임관은 교육수행 기록을 관리해야 한다.

- 제18조 (보직변경 등 인사이동시)** ①보직변경 등 인사이동시 업무시스템에 대한 접근권한을 인사발령과 함께 신속하게 변경 또는 조정하여야 한다.
- ②인사이동시 PC에 저장된 업무관련 파일은 삭제해야하며, 업무관련 파일이나 정보유출에 대한 책임은 해당PC 사용자에게 있다.

- 제19조 (퇴직 및 계약해지 시)** ①퇴직자는(계약직 포함) 재직 중 보유 한 모든 정보자산(사용PC, 보조기억매체, 업무자료 및 문서, 출입증 등)을 반환해야 할 의무가 있으며, 해당 부서장은 퇴직자의 정보자산을 팀에 귀속시킬 수 있도록 할 책임이 있다.
- ②퇴직 절차가 완료된 퇴사자에 대해 인사발령을 시행하고, 퇴직 처리된 퇴사자의 계정이 삭제될 수 있도록 요청한다.
- ③정보보호담당관은 퇴직자에 의한 정보유출이 의심되거나 위험이 있는 경우 퇴직 처리

전에 사용자의 계정을 삭제 조치할 수 있다.

④퇴직 절차 내, 정보 유출 방지를 위한 비밀유지 서약서를 포함하고 징구한다.

제20조 (보안규정위반자에 대한 처리) 보안담당관은 보안과 관련된 규칙, 지침 등을 위반하는 행위를 한 자에 대하여 보안심사위원회의 심의를 거쳐 총장에게 징계를 요구할 수 있다.

제7장 물리적 보안

제1절 보호구역 설정 및 통제

제21조 (보호구역 설정) ①본교의 물리적 보안을 위해 보호구역을 설정하여 관리 한다.

②보호구역은 그 중요도에 따라 통제구역, 제한구역으로 구분하며, 본교의 보호구역은 보안업무처리 규칙 제3장 제41조 규정을 준수한다.

③보호구역에 대한 통제는 본 규칙 외에도 보안업무처리 규칙 제3장을 준수하여 관리한다.

제22조 (통제구역의 통제) 통제구역으로 지정된 장소는 다음과 같은 통제를 적용한다.

1. 출입통제 및 감시를 위해 출입통제시스템, 감시카메라(CCTV) 등을 설치한다.
2. 비인가자의 출입이 제한되는 '통제구역' 표시를 하여야 한다.
3. 통제구역의 출입 권한 등록은 최소한의 인원으로 제한하고, 인가자 외의 인원 출입 시 담당자 인솔 하에 출입한다.

제23조 (제한구역의 통제) 제한구역으로 지정된 장소는 다음과 같은 통제를 적용한다.

1. 출입통제를 위해 출입통제시스템을 설치한다.
2. 퇴직, 보직 변경된 교직원에 대한 불필요한 출입권한은 즉시 해제되어야 한다.
3. 외부자의 제한구역 내 출입은 업무상 필요에 따라 결정되어야 하며, 담당자에 의하여 이들의 제한구역 내 활동은 지속적으로 관리·감독되어야 한다.

제24조 (보호구역 재해 대비) ①화재대비 소화기를 비치한다.

②적정한 온·습도를 유지하기 위한 항온항습기를 설치 및 운용하도록 한다.

③비상시에 대비하여 휴대용 조명기기를 비치한다.

④재해 방지 설비에 대한 점검을 정기적으로 실시한다.

⑤주기적인 재해대비 훈련에 대한 계획수립 및 훈련을 실시한다.

⑥재해복구를 위한 방안을 마련하도록 한다.

제25조 (장비 설치 및 보호) ①장비는 물리적·환경적 위협이나 위험, 또는 외부인의 접근으로부터의 위험을 줄일 수 있도록 설치하고 보호한다.

②비밀정보를 다루는 원격터미널 또는 모니터는 비인가자가 외부로부터 투시가 될 수 없도록 배치하며, 특별한 보호가 요구되는 정보시스템은 격리된 장소에서 별도로 관리한다.

③비상시 사용될 백업 장비 및 자산은 원격지에 보관한다.

④정보시스템은 화재 등에 대비하여 건물 외벽과 거리를 두고 배치하고, 가능한 취사시설, 화장실 등으로부터 거리를 두고 배치한다.

⑤정보시스템에 연결된 전력과 통신 케이블은 가능한 매설하고, 매설이 어려울 경우 보호를 위한 방안을 마련해야 한다.

⑥장비는 정전이나 기타의 전기적 장애로부터 보호한다.

⑦장비 및 설비는 정기적인 점검을 월 1회 이상 실시하여 장애나 고장으로부터 보호한다.

제26조 (장비 폐기 및 재사용) ①중요한 정보를 담고 있는 저장 장치의 폐기 및 재사용 시에는 물리적으로 파괴하는 등 적절한 정보보호 대책을 적용한다.

②하드디스크와 같은 저장 매체를 포함하는 모든 종류의 장비는 폐기되기 전에 저장 매체로부터 중요한 데이터 및 라이선스가 있는 소프트웨어가 제거되었는지 확인한다.

③비밀정보를 포함한 보고서 등의 문서는 안전하게 파지 또는 소각하며, 하드 디스크, 광 파일, 마그네틱 테이프 등의 매체를 폐기 처분하고자 할 때에는 인가된 안전한 방법을 사용하여 완전 포맷 또는 삭제한 후 폐기한다.

④비밀정보 폐기와 관련된 기록은 향후 감사를 위해 유지한다.

제27조 (자료보안) ①비밀정보가 담긴 저장매체, 출력된 문서 또는 PC 등은 비인가자의 접근으로부터 보호한다.

②정보보호담당관은 보호구역내에 생성 및 유통되고 있는 종이문서와 PC 화면으로부터 비인가자에게 정보가 유출되는 것을 방지하기 위하여, 보호구역 내의 직원들을 대상으로 보안활동을 준수토록 한다.

③주요 서류 및 휴대용 저장매체(노트북, PDA, 외장형 하드디스크 등)를 사용하지 않을 경우, 시건 장치가 된 캐비닛이나 창고에 보관한다.

제2절 사무실보안관리

제28조 (출입통제) ①본교 사무실 출입문에는 출입통제장치를 설치해야하며, 비인가자의 출입을 통제해야 한다.

②근무시간 이후에는 출입통제장치가 잠금상태로 되어 있어야 한다.

제29조 (출입증 착용 및 관리) ①전 교직원은 출입 시 출입증을 착용해야 한다.

②출입증을 분실 또는 도난당한 경우, 해당팀으로 즉시 통보해야 한다.

③교직원은 자신의 출입증이 분실되지 않도록 주의한다.

제30조 (사무실 보안 활동) ①전 교직원은 책상 위에 주요 문서나 저장매체를 방치하지 않도록 한다.

②노트북은 퇴근 시 반드시 잠금장치 내에 보관 또는 시건장치를 하여 도난 및 분실에 유의한다.

③공용 캐비닛에는 정·부 책임자를 지정하고 퇴실 시 항상 잠근 후 열쇠는 안전한 곳에 보관하여야 한다.

④개인 서랍은 잠금장치를 설치하고 퇴근 시 항상 잠금을 확인한다.

⑤최종 퇴실자 또는 부서 정보보안담당자는 매일 퇴근 전 사무실의 보안점검을 실시하고 보안점검 일지를 작성해야 하며, 분임정보보호담당관은 작성된 보안일지에 대하여 월별 주기로 확인을 수행한다.

제3절 전산장비실 보안관리

제31조 (출입권한 관리) ①전산장비실 출입권한은 정보화운영팀 직원에 한하여 허가되며, 전산장비실 출입권한자 명단을 작성하여 전산장비실내에 비치한다.

②전산장비실 출입권한이 신규로 필요로 한 경우 정보보호담당관의 승인 후, 해당 인원의 출입권한을 등록한다.

③정보보호담당관은 퇴사 및 보직변경으로 인하여 전산장비실 출입권한의 변동이 발생한 경우 우선적으로 해당인원의 전산장비실 출입권한을 삭제한다.

④정보보호담당관은 출입 기록을 일정 기간 보존하고, 출입 기록 및 출입 권한을 주기적으로 검토하여야 한다.

제32조 (외부인 출입통제) ①전산장비실은 비인가자의 출입을 통제하여야 하며 ‘[별지 제5호 서식] 출입관리대장’을 비치하여 모든 출입자를 기록해야 한다.

②외부인이 전산장비실을 출입하는 경우 출입권한자가 동행하도록 한다.

③외부인의 전산장비실 출입 시 목적, 출입 및 퇴실시간 등을 출입관리대장에 기록하고 동행한 출입권한자가 확인서명을 하여야 한다.

제33조(정보통신장비의 반입·출입 통제) ①정보보호담당관은 정보통신장비의 수리, 교체

및 대체, 대여 등으로 정보통신장비가 반입·반출되는 경우, 정보통신장비의 반입·반출을 통제하여야 한다.

②정보보호담당관은 정보시스템 장비의 반입·반출을 하는 경우 관련 기록을 ‘[별지 제6호 서식] 반입·반출 관리대장(전산장비실)’에 기록한다.

③정보보호담당관은 반출입 통제절차에 따른 관련 기록 ‘[별지 제6호 서식] 반입·반출 관리대장(전산장비실)’을 유지·관리하고, 절차 준수 여부를 확인할 수 있도록 반출입 이력을 주기적으로 점검하여야 한다.

④장비 반출일 경우 해당 장비내의 저장매체에 저장된 정보가 복구 가능하지 않도록 삭제되었는지 확인한 후 장비를 반출하도록 한다.

⑤주요 정보시스템이 위치한 통제구역 등에서 보조기억매체 사용을 제한해야 하며, 불가피하게 사용할 경우, 관리책임자의 승인을 득한 후 사용한다.

⑥전산장비실 내 작업이 통제 절차에 따라 적절히 수행되었는지 여부를 확인하기 위하여 작업 기록을 주기적으로 검토하여야 한다.

1. 작업 검토 : 사전 승인 내역, 출입 기록, 작업 기록 등에 대한 정기적 검토 등
2. 검토 방법 : 출입 신청서와 출입 내역 일치성 등

제8장 PC 보안

제34조 (PC 보안관리) ①개인이 사용하는 PC의 정보보안 관리에 대한 1차 책임은 PC 사용자에게 있으며, 교직원 PC사용자는 다음의 보안대책을 강구해야 한다.

1. CMOS(부팅), 로그인 및 화면보호기에 각각 비밀번호 설정 후 3개월 단위로 변경
2. 10분 이상 PC 작업을 중단 시 비밀번호가 적용된 화면보호기 작동
3. 최신의 바이러스 백신 S/W 설치 및 주기적인 업데이트
4. 개인정보점검 S/W 설치 및 주기적인 업데이트
5. P2P, 메신저, 웹하드 등 업무와 무관하거나 보안에 취약한 프로그램의 사용 금지

②공유폴더는 사용하지 않는 것을 원칙으로 하며, 업무상 목적으로 필요한 경우에는 반드시 공유폴더에 패스워드를 설정하고, 사용이 완료된 후에는 공유 설정을 제거해야 한다.

③노트북은 도난 및 분실을 예방하기 위해 물리적 시건장치를 설치하여 사용해야 하며, 외부 출장 시에도 책상위에 방치하지 말고 시건장치를 설치하거나 디스크 암호화 후 사용하여야 한다.

④모든 PC사용자(노트북 등의 모바일 컴퓨터 포함)는 적법한 절차를 거쳐 취득한 정품 소프트웨어만을 사용해야 하며 사용권한이 없거나 임의로 복제된 불법소프트웨어를 설치해서는 안 된다.

⑤업무상 취급되는 개인정보 등 중요정보를 PC에 저장 시 암호화하여 저장하도록 하며,

정보 이용 목적 달성 시 지체없이 삭제하여야 한다.

⑥매월 세 번째 수요일을 사이버 보안 진단의 날로 지정하여 사용자는 PC 업데이트 및 보안 취약점 점검, 악의적인 바이러스 및 불법 소프트웨어 등이 설치되어 있는지를 점검하여야 한다.

⑦사용자가 노트북, 넷북, 스마트폰 등과 같은 모바일 컴퓨터를 이용하는 경우에는 위와 같은 일반 PC보안 사항을 준수하여야 하며, 업무자료가 저장되지 않도록 시스템 종료 시 사용자 파일 자동삭제와 같은 보안수단 설치를 강구하여야 한다.

⑧업무에 사용되는 단말기에 대하여 다음의 보안 통제 정책을 이행하여야 한다.

1. 업무용 단말기 허용 기준 수립
2. 업무용 단말기 통한 업무 사용 범위 설정
3. 업무망 연결 시 인증 방안
4. 업무용 백신 설치 보안프로그램 설치 등
5. 업무용 단말기 사용에 따른 보안 설정 정책 및 오·남용 모니터링 대책 수립

제35조 (PC 비밀번호 설정 및 관리) ①PC사용자(노트북 포함)는 CMOS(부팅)로그인, 화면 보호기 패스워드를 설정하여 비인가자의 접근을 통제하여야 한다.

②PC에서 사용하는 비밀번호는 다음 각 호 사항을 반영하여 영문·숫자·특수문자가 포함된 9자리 이상으로 정하고, 분기 1회 이상 주기적으로 변경 사용하여야 한다.

1. 사용자계정(ID)과 동일하지 않은 것
2. 개인 신상 및 부서명칭 등과 관계가 없는 것
3. 일반 사전에 등록된 단어는 사용을 피할 것
4. 동일단어 또는 숫자를 반복하여 사용하지 말 것
5. 이전에 사용된 비밀번호는 재사용하지 말 것
6. 동일 비밀번호를 여러 사람이 공유하여 사용하지 말 것
7. 관리자계정과 사용자계정의 비밀번호를 다르게 부여
8. 초기 할당된 임시 비밀번호는 사용자 로그인 후 즉시 변경

제36조 (PC 및 노트북 반출·입 관리) ①PC(노트북)의 반출 시 해당 부서별 반출·입 내역을 '[별지 제7호 서식] 보조기억매체(전산장비 포함) 반출·입 대장'에 기록해야 한다.

②PC 사용자는 반출된 PC(노트북) 반입 시 바이러스 백신프로그램으로 바이러스 및 악성코드 감염여부를 점검한다.

③개인소유의 PC(노트북 등)는 본교 내부로 반입 또는 반출하여 사용해서는 안 된다. 다만, 부득이한 경우에는 부서장의 승인을 받은 후 반입 또는 반출할 수 있다.

④PC에 설치 또는 부착된 하드웨어를 임의로 변경, 제거하거나 본교 외부로 반출해서는 안 된다.

제37조 (PC 유지보수) ①PC 유지보수는 인가된 직원(또는 외부업체 직원)에 의해서만 수행되어야 한다.

②PC 또는 PC내 하드웨어를 유지보수(교체·반납·폐기)를 위해 본교 외부로 반출할 경우 다음의 보안대책을 강구한다.

1. PC에 저장된 데이터가 복구가 되지 않도록 삭제 또는 하드디스크를 분리
2. PC수리인력에게 [별지 제8호 서식] ‘정보보안 서약서(외부자용)’ 징구

제38조 (유해 소프트웨어에 대한 통제) 공식적으로 인가되지 않은 프로그램의 사용은 바이러스, 트로이 목마와 같은 악성 코드들이 포함되어 있을 가능성이 높으며 이러한 악성 코드 들은 조직의 중요 정보 노출, 파괴 등을 유발할 수 있으므로 사용자는 프로그램 사용에 대해 다음 사항을 준수한다.

1. 사용자는 업무에 불필요 또는 불법 소프트웨어를 사용하지 않고, 정품 소프트웨어만을 사용한다.
2. 불확실하거나 출처가 명확하지 않은 파일, 신뢰할 수 없는 네트워크로부터 획득된 파일은 사용하기 전에 바이러스 검사를 한다.
3. 사용자는 월 1회 이상 악의적인 바이러스, 불법 소프트웨어 등이 설치되어 있는지를 점검한다.
4. 악성코드 감염 발견 시 네트워크 케이블을 분리하고, 정보보호담당관에게 보고한다.

제9장 E-mail, 인터넷 보안관리

제39조 (E-mail 사용의 제한) ①E-mail 사용자는 부서장의 허가를 받지 않은 정보 또는 외부에 공개할 수 없는 내부 정보를 외부에 발송하지 않는다.

②스팸메일 등 불법 메일 등을 송신하거나 타 직원의 E-mail 계정을 도용할 수 없다.

③정보시스템 자원의 낭비를 초래하는 스팸메일, 반복메일 등은 전송 및 배포를 금지한다.

④모든 E-mail 사용자는 제3자의 지적재산권, 저작권을 침해하는 내용, 명예훼손, 사기, 바이러스 유포 등의 불법적인 행위에 대한 내용을 E-mail에 포함하지 않는다.

⑤타인의 E-mail 내용 및 비밀번호를 중간에서 전자적으로 도청하지 않는다.

⑥E-mail이 암호화되지 않은 경우, E-mail 사용자들은 신용카드번호, 패스워드 등 개인의 중요한 정보를 E-mail 내용에 포함시켜 보내지 않아야 한다.

⑦내부정보를 외부로 송신하기 위해서는 사전에 그 타당성에 대해 해당 전결권자의 승인을 득해야 하며, 내용의 중요성에 따라 선택적으로 암호화하여 전송한다.

제40조 (E-mail 이용 시 업무처리 절차) ①E-mail 계정은 정보시스템(아우누리) 가입 후 메일시스템 접근 시 자동으로 생성함을 원칙으로 한다.

②E-mail 관리 원칙

1. 한 명의 직원 당 1개의 E-mail 계정 부여를 원칙으로 한다. 단, 업무 목적상 필요한 경우 업무용 계정을 별도로 신청할 수 있다.
2. 직원의 E-mail 주소 디렉토리는 공개적으로 접근하지 못하도록 조치한다.

③업무용 E-mail 사용 기준

1. E-mail을 통한 업무자료 수발신은 내부 웹메일 시스템을 사용한다.
2. 외부 사설메일(Naver, Daum, MSN 등)을 이용한 업무자료 송수신은 하지 않는다.

④메일 이용 중 사용자의 PC 자료를 파괴하거나 탈취하려는 목적의 악성메일 수신시 **정보보호담당관**에게 통보하고, **정보보호담당관**은 조사 후 발신지 차단 등의 보안조치를 실시한다.

제41조 (인터넷 접속에 대한 보안) ①다음의 사이트는 업무시간 중 접속을 금지한다.

1. 유해 사이트
2. P2P 사이트
3. 증권관련 사이트 등 업무와 관련성이 없는 사이트
4. 북한관련 사이트 등 기타 접속 금지의 필요성이 인정되는 사이트
5. 외부 메신저, 메일 관련 사이트 및 어플리케이션

② 업무와 관련이 있는 사이트 외의 웹 사이트의 Active-X 등 추가기능을 설치하지 않는다.

③악성 자료를 포함하는 사이트를 발견했을 경우, 해당 사이트의 URL을 정보보호담당관에게 통보하고, 정보보호담당관은 조사 후 유해사이트차단시스템 등의 보안시스템을 사용하여 해당 사이트의 접근을 차단한다.

제10장 보조기억매체 관리

제42조(보조기억매체 등록 및 관리) ①본교 교직원은 원칙적으로 보조기억매체를 사용할 수 없으나 업무상 불가피하게 사용할 경우 보안기능이 포함된 보조기억매체를 사용하되, 관리대장에 기록하여 안전하게 관리하여야 한다.

②보조기억매체 등록 및 관리와 관련된 세부사항은 ‘USB메모리 등 휴대용 저장매체 보안 관리지침’을 따른다.

제11장 서버 보안

제43조 (정보시스템 보안관리) ①정보보호담당관은 정보통신시스템(정보통신망 포함)의 효율적인 보안관리를 위하여 정보통신시스템별로 관리책임자(이하 ‘시스템관리자’라 한다)를 지정 운영하여야 한다.

②시스템관리자는 각종서버·PC·정보통신장비 등 정보통신시스템이 비인가자에게 불필요한 서비스를 허용하지 않도록 보안기능을 설정하여야 한다.

③시스템관리자는 보안점검도구를 이용하여 연 1회 이상 정보통신시스템의 보안취약성을 진단하고 그 결과를 정보보호담당관에게 제출하여야 한다.

④시스템관리자는 주기적으로 불필요한 포트의 사용여부를 점검하여, 불필요한 포트 사용이 확인되는 즉시, 해당 포트를 삭제하는 등의 보안조치를 수행한다.

⑤중요정보를 취급하는 정보시스템은 관리자 권한으로 시스템에 접근하는 경우, 지정된 IP에서만 접근할 수 있도록 한다.

제44조 (서버 시스템의 설치) ①서버 시스템 설치 시 아래의 각호의 사항을 준수하여야 한다.

1. 신규 시스템을 도입 시 시스템 보안설정, 서버백신, 장애관리 등의 도구를 설치해야 한다.
2. 시스템관리자는 신규로 도입 설치되는 서버 시스템에 서버 취약점 점검도구를 설치하여 시스템 및 OS의 취약점 점검을 수행하며, 점검결과 발견된 취약점에 대해 조치하고 그 결과를 정보보호담당관에게 제출하여야 한다.
3. 시스템관리자는 신규 시스템 설치 및 변경 사항을 정보자산 관리목록에 갱신해야한다.

②소프트웨어 설치 아래의 각호의 사항을 준수하여야 한다.

1. 발주부서 담당자는 서버에 설치된 소프트웨어의 현황을 목록으로 만들어 관리하며 변경 시 현황을 수시로 업데이트 한다.
2. 서버 시스템에 설치되는 소프트웨어는 정보보호담당관의 승인을 얻은 후 설치한다.
3. 발주부서 담당자는 소프트웨어 설치작업 후 해당 서버의 소프트웨어 설치 현황목록에 추가한다.
4. 업무통제나 시스템을 무력화 할 수 있는 유틸리티의 사용은 통제한다.

③소프트웨어 설치 시 아래의 각호의 사항은 제한하여야 한다.

1. 서버에는 업무 목적 외의 불필요한 프로그램을 설치할 수 없다.
2. 불법 소프트웨어는 설치할 수 없다.
3. 원격관리 소프트웨어 등 서비스 관리 목적상 불가피하게 설치해야 할 필요성이 있을 때에는 자체 보안대책을 마련하여 정보보호담당관에게 승인을 얻는다.

④시스템관리자는 파일시스템을 구성할 때 시스템 데이터와 일반 데이터를 논리적 또는 물리적으로 분리하여 설치한다.

제45조 (보안설정 적용) ①시스템관리자는 주기적인 패치 및 보안 설정을 적용한다.

②모든 서버는 로그인을 허용하기 전에 다음과 같은 보안권고문을 공지한다.

“서버관리자이외또는부당한방법으로정보통신망및정보시스템에접속하거나정보를삭제,변경,유출하는자는관련법령에따라처벌을받게됩니다.”

③서버 로그인 시 또는 웹서버 정보에서 OS버전, 서비스정보 등의 취약점 유추가 가능한 정보가 누출되지 않도록 설정한다.

④시스템의 보안 설정된 정보와 로그는 임의적으로 삭제되지 않도록 한다.

제46조 (시스템 접근 기록 관리) ①시스템 접속기록은 접속일시, 사용자 ID, 접속 IP, 행위 등이 포함되어야 한다.

②시스템 접근 및 사용에 대한 책임 추적성을 확보하기 위하여 시스템 가동 및 종료, 설정 변경, 중요파일 접근로그, 관리자 계정 명령어 사용내역 등의 로그를 기록한다.

③사고발생시 책임추적이 가능하도록 시스템 접근기록을 6개월 이상 보관하여야 한다.

④정보보호담당관의 사전 승인이 없는 한 모든 시스템의 로그는 비인가자가 접근할 수 없으며 시스템 로그를 비인가자가 열람하거나, 훼손하는 경우 보안심사위원회를 통해서 처벌하거나, 외부자의 경우 민·형사상 법적 조치를 취한다.

⑤시스템관리자는 정기적으로 시스템 접근기록을 검토하여 비인가자의 접속 시도, 정보 위·변조 및 무단삭제 등의 의심스러운 활동이나, 침입흔적 발생 시 정보보호담당관에게 보고하고 조치를 취해야 한다.

제47조 (계정 및 패스워드 관리) ①시스템관리자는 사용자계정의 등록·변경·폐기 시 정보보호담당관에게 그 결과를 보고하여야 한다.

②시스템관리자는 3개월 이상 미사용 계정, 사용자의 퇴직 또는 보직변경 등으로 사용하지 않는 사용자계정에 발생할 경우 이를 신속히 삭제하여야 한다.

③5회에 걸쳐 사용자인증 실패 시 정보통신시스템 접속을 중지시키고 비인가자 침입 여부를 확인 점검하여야 한다.

④패스워드는 영숫자, 특수문자 등을 혼합하여 9자리 이상으로 정하고 분기 1회 이상 주기적으로 변경 사용하여야 한다.

제48조 (권한관리) ①서버 내 정보에 대한 접근 권한은 시스템관리자가 결정하여 신청하며 정보보호담당관은 접근 권한을 검토 후 부여한다.

②시스템관리자는 개인의 계정으로 접속한 후에 관리자 권한을 획득한다.

- ③일반 사용자는 다른 사용자의 홈 디렉터리 혹은 시스템 관리에 관한 파일 혹은 디렉터리에 접근할 수 없도록 제한한다.
- ④사용자가 서비스 중지 등을 일으킬 수 있는 명령어를 사용하거나 파일 실행을 할 수 없도록 제한한다.
- ⑤사용자는 시스템관리자 및 정보보호담당관의 사전 승인 없이 운영체제의 접근 통제를 우회할 수 있는 프로그램을 사용할 수 없도록 제한한다.
- ⑥관리자 권한 등의 중요 권한을 일반 사용자에게 생성해주지 않는다.
- ⑦슈퍼유저 계정을 이용한 FTP 접속권한을 해제한다.
- ⑧불필요한 RPC, SMB등 통신 권한을 해제한다.

제49조 (접근통제 관리) ①업무상 접속할 필요가 있는 사용자를 파악한 후 보안 도구를 이용해 IP 주소 기반의 접근 제어를 한다.

- ②시스템관리자는 서버가 정상적으로 동작하지 않을 경우 정상적으로 동작될 때까지 사용자의 접근을 제한할 수 있다.
- ③시스템관리자는 비인가자의 불법적인 접근 및 서비스 중지 등을 예방하기 위해 업무적으로 불필요하거나, 침해의 위협이 있는 네트워크 서비스를 제공하지 않는다.
- ④시스템관리자는 접근통제 세부내역을 주기적으로 검토하여야 한다.

제50조 (원격접근 보안관리) ①사용자가 서버에 접속할 경우 반드시 사용자 계정과 패스워드 또는 보다 강화된 인증 방법을 적용하여 접근 가능하도록 한다.

②인증방법은 서버 시스템이 제공하는 서비스 내용과 중요도에 따라 결정하며 다음과 같은 방법 등을 사용한다.

1. 사용자 계정, 패스워드
2. 음성, 지문, 홍채 등 신체적 특성을 이용한 인증
3. 비밀번호 발생기, 디스켓, IC카드 등 소지형 인증
4. 공개키 기반 인증 (PKI)

③인증 서버를 구축할 경우에는 인증 서버의 장애로 인한 서비스 중단 등이 발생하지 않도록 병렬구성을 원칙으로 한다.

④중요 서버에 접근 시에는 SSH(Secure Shell) 등의 암호화된 통신 프로토콜 사용을 원칙으로 한다.

⑤로그인 화면에서는 로그인 관련 정보만 표시한다. 조직이나 운영체제, 네트워크 환경, 내부적인 사항과 같은 정보는 로그인이 성공적으로 이루어진 후에 표시되도록 한다.

⑥사용자가 시스템에 로그인 실패 시 시스템 침해의 원인이 될 만한 정보를 사용자에게 보여주지 않도록 조치한다.

⑦연속적으로 3회 이상 패스워드를 잘못 입력할 경우 세션을 차단 후 정보보호담당관에

게 해당 사실을 통지하고 비인가자의 침입여부를 확인 및 점검해야 한다.

⑧사용자가 서버 로그인에 성공하였을 경우 가장 최근에 성공적으로 접속한 시간, 날짜, 터미널 등의 정보를 화면에 표시한다.

제51조 (관리자 보안 이행사항) ①서버에 접속한 후 사용자나 다른 시스템으로부터 일정시간(10분 이하) 동안 어떤 입력도 일어나지 않으면 자동적으로 로그오프 시키거나 세션을 중단시키는 것을 원칙으로 한다. 단, 개발 업무나 서버 운영상 필요성이 인정되는 경우 예외로 할 수 있다.

②통제구역 이외의 장소에 설치된 서버는 시스템관리자 및 사용자가 5분 이상 자리를 비울 경우 패스워드가 설정된 화면보호기가 작동되도록 하거나 로그오프하여 비인가자가 접근할 수 없도록 한다.

제52조 (외부망에 대한 접근보안관리) 정보시스템을 외부에서의 네트워크를 통해 원격으로 접속하여 정비하는 것을 원칙적으로 금지하여야 한다. 다만, 부득이한 경우에는 아래의 각호에 해당하는 보안대책을 강구하고 한시적으로 허용하여야 한다.

1. 원격접속 수행자에게 임시 접근권한 부여
2. 접근권한의 사용시간 명시, 시간경과 후 접근권한 삭제
3. 원격정비 시스템의 IP 사전 파악, 지정된 시스템에서만 수행
4. 원격시스템과의 통신정보를 점검하여 실행코드에 악성코드 유입 방지
5. 원격정비를 수행할 때 대상 정보시스템을 내부망과 분리
6. 원격 정비기록을 유지, 정비결과 서버관리자에게 보고
7. 원격 정비자가 네트워크를 통해 원격지 컴퓨터 파일을 자신의 컴퓨터 파일처럼 접근하여 작업할 수 있도록 하는 등 해킹에 취약한 방식으로 원격정비 금지

제53조 (패치 및 변경 통제) 패치나 시스템 파라미터(IP, 사용자 계정, 권한 설정, 환경설정 값 등)를 변경할 시에는 그와 관련된 모든 사항(변경값, 변경 사유, 승인자, 시행자, 일자, 해당 서버 등)에 대한 증거를 남긴다.

②운영시스템에 패치를 적용하는 경우, 운영 시스템의 중요도와 특성을 고려하여 영향도 분석 후 적용한다.

③패치 적용을 위한 영향도 분석 시 적용이 어려운 경우, 그 사유와 추가 보완대책을 마련하여 정보보호담당관에게 보고하고 그 현황을 관리한다.

제54조 (웹서버 등 공개서버 관리) ①외부인에게 공개할 목적으로 설치되는 웹서버 등 각종 공개서버는 내부망과 분리하여 운영하고 보안적합성이 검증된 침입차단시스템을 설치하는 등 보안대책을 강구하여야 한다.

- ②서버에 접근할 수 있는 사용자계정을 제한하며 불필요한 계정은 삭제하여야 한다.
- ③홈페이지 게재내용은 운영부서 부서장의 심의를 거쳐 개인정보·비밀내용 등 비공개 자료가 포함되지 않도록 하여야 한다.
- ④공개서버는 업무서비스를 제외한 모든 서비스 및 시험·개발도구 등의 사용을 제한하도록 보안기능을 설정하여야 한다.
- ⑤공개서버는 운영 전 보안취약점을 점검하고 모든 취약점이 수정되었음을 확인 및 보안 조치 실시 후 운영하여야 하며, 운영 중에도 보안취약성을 연 1회 이상 점검하여 시스템 및 자료의 위·변조, 훼손여부를 확인하고 그 결과를 정보보호담당관에게 제출하여야 한다.
- ⑥보안사고에 대비하여 서버에 저장된 자료의 철저한 백업체계를 수립·시행하여야 한다.
- ⑦정보보호담당관은 공개서버의 취약점이 수정되지 않은 상태로 운영될 경우, 취약점 수정을 위하여 해당 서버의 운영 또는 서비스를 중단시킬 수 있다.

제55조 (취약점 점검) ①시스템관리자는 시스템 불법 접근 및 해킹 프로그램(백도어 및 스파이웨어 등)의 설치 여부 점검 등 일상적인 보안활동을 수행한다.

②정보시스템에 대한 종합 점검은 연 1회 이상 실시하고, 시스템의 변경, 외부 시스템의 이관 및 신규 시스템 도입 등 필요시 수시 점검을 실시한다.

1. 정보보호담당관은 종합점검 계획을 수립하여 시행하고, 발견된 취약점에 대하여 해당 팀에 통보한다.
2. 시스템관리자는 담당 시스템에 대하여 수시로 점검을 실시하고, 종합점검 및 수시점검 시 발견된 취약점에 대한 보완계획을 수립하여 시행하고 그 결과를 기술보안 담당관에게 제출하여야 한다.
3. 단기 조치가 어려운 취약점에 대하여 그 사유를 기록, 관리한다.
4. 취약점 조치를 위하여 관련 팀 및 업체의 협력이 필요할 경우에는 정보보호담당관등 관련 소관 부서담당자 및 업체 직원을 소집하여 조치방안을 강구한다.
5. 취약점 점검 대상, 기간, 주요 점검항목, 점검결과 및 조치 사항을 포함하는 ‘취약점 점검 결과보고서’를 작성하여 이력을 관리한다.
6. 정보보호담당관은 외부 시스템의 이관 시 서버, 응용시스템 등 분야별 수시점검 결과 발견된 취약점에 대한 보완여부를 확인하고, 취약점을 조치하기 위하여 방안을 강구할 수 있다.

제56조 (시스템 성능관리 및 유지보수) ①시스템관리자는 서버의 자원 오용을 방지하기 위해 주기적으로 점검, 관리하고 지속적으로 모니터링 해야 한다.

②시스템관리자는 서버 자원의 모니터링 결과를 통해 시스템 성능향상을 도모한다.

③시스템관리자는 서버 자원 요구사항(임계치)을 초과하는 경우, 조치 방안을 수립 및 검

토하여 이행한다.

제57조(백업 관리) ①시스템관리자는 정보화자료 백업 및 소산계획을 수립하고 백업을 실시한다.

②백업대상 선정 및 주기는 시스템별 중요도 및 현업 팀의 추가 요구사항을 반영하여 결정한다.

③백업에는 정기적인 백업, 비정기적인 백업을 포함하며, 비정기적인 백업은 시스템 변경 작업, 소프트웨어 설치작업, 하드웨어 교체작업 등의 작업 전에 반드시 수행한다.

④백업 수행 후에는 백업일자, 백업대상, 백업매체 등을 포함하여 '[별지 제 17호 서식]백업결과보고서'를 작성 후 보관한다.

⑤백업시스템 도입 후 최초 적용 시 정기적인 항목들(보관기간, 방식, 데이터베이스 백업 모드, 소산백업 여부)을 결정하여야 하며, 운영도중 변경사항이 발생하면 충분한 검토 및 승인을 통해 이를 반영하여야 한다. 그리고 백업데이터의 중요도에 따라 백업주기를 결정한다.

제58조 (백업 대상 및 주기) ①백업대상은 데이터의 파손 시 복구의 필요성이 요구되는 본교의 주요 데이터이며 다음과 같은 정보들이 이에 해당한다.

1. OS 및 유틸리티 프로그램
2. 데이터베이스 파일 : 업무데이터 및 데이터베이스 구성파일
3. 네트워크 장비 구성파일 및 로그파일
4. 정보보안시스템 정책 및 로그파일
5. 기타 필요로 하다고 생각되는 파일

②백업대상에 대한 백업 및 보관주기는 정보보호업무 연속성 관리지침 제4장 제10조 백업 및 소산 계획 수립을 기준으로 정한다.

③백업 데이터는 원격지의 안전한 장소에 분산보관 하고, 그 기록을 관리한다.

제59조 (서버 시스템 백업매체 관리) ①백업매체는 비인가자가 접근할 수 없는 격리된 곳에 보관하여, 비인가자에 의한 백업 정보의 유출이 일어나지 않도록 한다.

②백업매체가 재난 등으로 인해 원본과 동시에 손실되는 것을 방지하기 위해 원본과 물리적으로 떨어진 장소에 보관하도록 하며, 물리적인 접근 통제 및 백업 일자 목록을 유지 관리한다.

③백업매체의 폐기 시 정보보호담당관의 승인을 득한 후 소각 폐기한다.

제60조 (복구관리) ①장애 발생 시 업무 연속성을 확보하기 위한 정보보호 업무 연속성 관리 지침 제28조 분류에 따라 문제가 발생한 부분이 서버운영에 별로 문제가 없을 경우 업

무 종료 후에 복구를 수행하고, 업무 중에 복구가 불가피하다고 판단되면 최소 시간에 복구를 할 수 있도록 복구의 종류를 파악하고, 즉시 복구를 수행한다.

②장애로 인하여 영향 받는 부서 및 업무를 파악하여 관련자에게 장애원인 및 복구 예정 시간 등을 통보하여 복구로 인한 업무손실을 최소화 한다.

③발생한 장애에 대한 조치 복구 결과를 ‘장애조치내역서’에 기록하여 관리한다.

④긴급사항 발생 시 선 조치 후 보고할 수도 있다.

제61조 (업무연속성) 시스템관리자는 장애 또는 재난에 대비하기 위해 업무연속성 계획을 수립하고 주기적으로 비상·복구 훈련등의 모의 훈련을 통해 점검한 후 그 결과를 정보보호담당관에게 제출하여야 한다. 세부사항은 업무연속성 관리 지침을 따른다.

제12장 네트워크보안

제62조 (외부망연동) ①다른 기관과의 정보통신망과 연결 사용하고자 할 경우에는 보안관리 책임한계를 설정하고 다음과 같은 보안대책을 수립·시행하여야 한다.

1. 네트워크 취약성 점검
2. 침입차단·탐지 시스템 설치 운용 등

②외부망과 접속하는 경우에는 전산자료 제공범위 및 이용자의 접근제한 등에 대해 **정보보호담당관**에게 보안성검토를 의뢰 후 승인을 받아야 한다.

③외부망 연결에 따른 보안취약성 해소를 위하여 접속자료를 주기적으로 분석하고 보안도구를 이용하여 정보통신망의 취약성을 수시 점검하여야 한다.

④인터넷 등 상용망 및 타 기관과의 정보통신망 연동 시 불법침입(해킹)을 방지하고 효율적인 보안관리를 위하여 연결지점을 지정 운용함으로써 임의 접속을 차단하여야 한다.

제63조 (네트워크 IP주소관리) ①내부 네트워크에서는 사설IP 주소를 사용하는 것을 권장하며 사용자 편의성을 고려하여 공인IP주소를 부여할 수 있다.

②네트워크관리자는 내부통신망에서 사용하는 IP주소를 사용자별, 그룹별로 분리하여 사용해야 하며, IP할당에 관한 자료가 외부로 유출되지 않도록 하여야 한다.

③네트워크관리자는 IP현황을 최신으로 관리해야 한다.

④각 부서에서는 IP사용자의 변동사항 발생 시 3일 이내에 네트워크 관리자에게 변동사항을 보고하여야 하며, 연 1회이상 전체 사용자의 IP현황을 조사하여 네트워크 관리자에게 보고하여야 한다.

⑤정보통신망 세부구성현황(IP 세부 할당 현황 포함)은 중요정보로 대외비 이상으로 지정

하여 관리하여야 한다.

⑥서비스, 사용자 그룹, 정보자산의 중요도, 법적 요구사항에 따라 네트워크 영역을 물리적 또는 논리적으로 분리하고 각 영역 간 접근통제를 적용하여야 한다.

제64조 (네트워크 장비 계정 및 권한 관리) ①네트워크 장비에는 관리자 계정 등 최소한의 계정만을 생성해야 한다.

②네트워크 장비에는 설치 시 기본적으로 생성되는 불필요한 계정을 삭제해야 하며 해당 계정이 필요한 경우 기본 패스워드를 변경하여 사용한다.

③네트워크 장비의 패스워드는 영문과 숫자를 조합하여 최소 9자 이상으로 설정하고 분기 1회 이상 주기적으로 변경해야 한다.

제65조 (네트워크 장비 접근제어) ①네트워크관리자는 미사용 포트에 대한 비인가자의 불법적인 접속을 방지하기 위하여, 네트워크 장비에 대한 물리적 접근통제를 수행하거나 미사용 포트는 사용 할 수 없도록 설정한다.

②네트워크 장비에 로그인시 적절한 경고 문구를 삽입 한다.

③필요치 않거나 사용되지 않는 정보통신망 서비스 기능은 제거 또는 중지한다.

④네트워크 관리자계정의 접속은 콘솔포트 및 특정 PC에서만 접근하도록 설정한다.

⑤네트워크 장비에 접근 시 사용자 인증을 수행하고, 다음의 사항을 준수한다. 단, 기능이 없는 장비는 제외한다.

1. 5회 이상 정확하지 않은 패스워드의 시도가 있는 터미널은 자동으로 세션을 종료한다.
2. 관리자와 사용자 모드를 지원하는 경우 분리 운영한다.
3. 터미널의 유희시간은 5분 이내로 제한하며, 이후 자동으로 접속이 종료되도록 설정한다.

⑥네트워크 장비에 대한 접근제어 등 정책을 주기적으로 검토하여 불법적인 접근이나 미사용 포트 사용을 방지한다.

제66조 (네트워크 시스템 변경 통제) ①네트워크관리자는 패치나 시스템 파라미터(IP, 사용자 계정, 구성정보 데이터 등)를 변경할 시에는 정보보호담당관과 협의하여 변경에 따른 잠재적 영향 평가를 실시하고, 이에 따른 관련기록을 남겨야 한다.

②영향평가 실시 후 구성정보나 네트워크 시스템 변경이 적절하다고 판단되는 경우, 작업 내용 및 영향평가 결과를 첨부하여 정보보호담당관의 승인을 받아야 한다.

③영향평가 실시 후, 운영 환경에 따라 즉시 패치 적용이 어려운 경우 그 사유와 보완 대책을 마련하여 정보보호담당관에게 보고하고 그 현황을 관리해야 한다.

④네트워크관리자는 네트워크 시스템 변경을 수행하기 전에 시스템의 현재 설정을 백업하여 이상 상황에 대비한다.

⑤네트워크관리자는 비인가 장비 발견 시 해당 장비의 사용을 중단시킬 수 있다.

제67조 (로그 및 백업관리) ①네트워크관리자는 모든 네트워크 시스템에 대해 시간을 동기화하여 로그 생성 시 정확한 시간이 기록되도록 한다.

②주요 네트워크 장비의 로그 정보는 실시간으로 로그가 저장 될 수 있도록 한다. 단, 해당 기능이 제공되지 않는 장비는 제외한다.

③주요 네트워크 로그는 6개월 이상 보관하여야 한다.

④네트워크 로그파일 및 구성정보는 일반사용자 권한으로 수정 및 삭제할 수 없도록 설정한다.

⑤네트워크관리자는 네트워크 구성 정보는 분기마다 백업하여 보관한다.

제68조 (원격근무 보안관리) ①정보보호담당관은 정보통신망을 활용하여 본교 이외의 환경에서 재택·파견·이동 근무를 수행하는 인원을 지정하고 명단을 관리해야 한다.

②원격근무를 수행하는 인원 에 대한 시스템 접근기록은 주기적으로 확인한다.

제69조 (무선랜 보안관리) ①본교 내의 모든 무선중계기(AP)는 정보보호담당관의 승인을 득한 후 설치 및 운영해야 한다.

②정보보호담당관은 주요 행정지역에서의 비인가자의 무선랜 무단 사용, 비인가 AP설치 등에 대해서 주기적으로 점검을 수행해야 한다.

③무선랜 인증을 위해서 WPA2 이상의 보안방식을 적용하고, 설정된 키 값은 주기적으로 변경해야 한다.

④비인가자가 AP 보안기능의 설정을 변경하지 못하도록 출고 시 AP 제조회사에서 설정한 AP 관리용 S/W의 ID, 패스워드를 변경하여 추측이 어렵게 설정한다.

제13장 어플리케이션 보안

제1절 설계 및 개발단계

제70조 (개발보안 일반) ①본교 행정부서에서 업무용 어플리케이션 및 홈페이지 등의 정보 시스템을 개발하는 경우 해당 부서의 장은 보안대책을 수립하고 보안요구사항을 정의해야 하며, 필요한 경우 정보보호담당관에게 도움을 요청할 수 있다.

②해당 프로젝트담당자는 정보시스템 개발 과정을 감독하고, 개발된 코드에 대한 점검과 테스트를 실시해야 한다.

③시큐어 코딩과 관련된 가이드라인은 행정안전부 및 한국인터넷진흥원에서 제시한 방안

을 기본으로 하며, 프로젝트 담당자는 해당 기준에 따라 어플리케이션을 개발하도록 감독해야 한다.

④해당 프로젝트담당자는 모든 사업 참여 인원에게 대하여 사전에 보안서약서를 징구하고, 개인정보보호 및 정보보안 등 보안 교육을 실시해야 한다.

제71조 (개발 환경) ①개발공간은 비 인가자의 출입이 물리적으로 통제된 작업공간에서 개발이 이루어져야 한다.

②개발 서버가 위치한 네트워크는 원칙적으로는 인터넷과 분리되어야 하고, 네트워크에 연결된 경우에는 비 인가자의 접근으로부터 보호하기 위한 보안대책을 강구해야 한다.

③개발시스템과 운영시스템은 물리적 또는 논리적으로 분리되어야 한다.

④개발환경과 운영환경의 분리가 어려운 경우, 보안 위협을 감소할 수 있도록 상호 검토, 상급자 모니터링, 변경 승인, 책임 추적성 확보 등의 보안대책을 마련하여야 한다.

⑤개발자의 PC는 컴퓨터 바이러스나 각종 보안 침해사고로부터 보호되어야 한다.

⑥개발자의 시스템 및 소스코드 접근은 공식적으로 허가된 경로만을 사용하여야 한다.

⑦운영환경으로 안전하게 이관하기 위한 통제 절차를 수립·이행하여야 한다.

1. 이관담당자 지정
2. 기능 테스트 완료 여부 확인
3. 이관 시 문제 대응 방안 (복귀 등)
4. 이관에 대한 책임자 승인
5. 이관에 대한 기록 보존 및 검토 (버전관리)

제72조 (보안기능 요건 반영) ①본교 프로젝트담당자는 어플리케이션 설계 및 개발시 ‘[별표1] 어플리케이션 보안기능 요건’을 반영하여야 한다. 단, 업무적으로 반드시 필요하거나 정보보호담당관의 승인을 득한 경우에는 그 사유를 기록하고 보안기능 요건을 반영하지 않을 수 있다.

②해당 프로젝트담당자는 설계 및 개발 완료시 ‘[별표1] 어플리케이션 보안기능 요건’ 반영 여부에 대해서 정보보호담당관에게 보고해야 한다.

③중요 정보의 전송 및 저장 시 국정원으로부터 승인을 얻은 암호화 기법을 사용하여 암호화해야 한다.

④네트워크를 통해 개인정보 및 로그인 정보 등 중요정보가 전송될 때에는 반드시 암호화된 상태로 전송되어야 한다.

⑤암호화 Key의 접근은 인가된 사람으로만 제한하도록 하며 암호화 Key는 일정주기마다 변경하여야 한다.

⑥암호화 Key는 필요시 복구가 가능하도록 별도의 매체에 저장한 후 안전한 장소에 보관(물리적 분리된 곳 등) 한다.

⑦암호화 Key 생성, 이용, 보관, 배포, 파기에 대하여 다음과 같은 내용이 포함된 정책 및 절차를 수립하여야 한다.

1. 암호키 관리 담당자
2. 암호키 생성, 보관(소산 백업 등) 방법
3. 암호키 배포 대상자 및 배포방법(복호화 권한 부여 포함)
4. 암호키 사용 유효기간(변경주기) : 암호키 변경 시 비용, 업무중요도 등 고려
5. 소스코드에 하드코딩 방식의 암호키 기록 금지에 관한 사항 등

제2절 테스트 단계

제73조 (테스트 데이터 보호) ①테스트를 위하여 실 데이터를 이용하고자 할 경우에는 정보보호담당관의 승인을 받아야 한다.

②테스트 수행자는 사용자의 중요정보가 포함될 경우 제공받은 실 데이터를 적절한 과정(익명화, 재생성, RENAME 등)을 통하여 테스트 데이터로 변환한 후 사용한다. 단, 실데이터를 변환하지 않고 테스트를 할 경우에는 정보보호담당관의 승인을 받아야 한다.

③실 데이터는 테스트 데이터와 분리되어야 하며, 테스트 데이터의 접근은 테스트 절차에 필요 최소 인원으로 통제되어야 한다.

④테스트 수행자는 테스트가 완료하여 필요 사유가 소멸되면 즉시 테스트 데이터를 삭제해야 한다.

제74조 (보안 점검) ①개발 완료 시 개발 소관부서의 장은 해당 시스템에 대한 보안취약점 점검(시스템, 어플리케이션 점검)을 수행한다.

②보안점검 결과 나타난 취약점은 보완조치를 수행하고, 정보보호담당관에게 그 결과를 제출한 후 운영해야 한다.

③개인정보를 취급하는 시스템의 경우 개인정보 영향평가를 실시한 후 운용한다.

제3절 운영 단계

제75조 (사용자 계정 관리) ①어플리케이션 신규 계정에 대한 권한은 사용에 필요한 최소 권한 만을 부여한다.

②공동으로 사용하는 ID를 부여하지 말아야 한다. 단, 업무상 필요시는 주관 부서장의 승인을 득해야 한다.

③계정(ID) 및 초기 비밀번호는 추측 가능한 학번이나 사번, ID 등으로 설정하지 말아야 한다.

④민감한 정보자산에 대한 사용자 접근 시, 날짜, 시간, 장소별 제한을 하는 등 강력한 접근

근통제 정책을 적용할 수 있어야 한다.

⑤불필요한 계정 및 권한에 대한 검토 및 삭제를 반기마다 1회씩 수행한다.

⑥전출 및 퇴직 등의 사유 발생 시, 어플리케이션 담당자는 사용자 ID를 신속히 삭제한다.

⑦사용자 퇴사 및 사용자 업무 등이 변경되어 계정의 삭제나 권한의 변경이 필요한 경우 인사발령사항을 기준으로 자동 계정 삭제 및 권한 변경을 원칙으로 한다. 단, 시스템이 인사시스템과 연동이 되어 있지 않거나 업무상 주관부서의 검증이 필요한 경우에는 주관부서의 담당자가 검증 후 처리 할 수 있다.

⑧대학 외부 네트워크를 통하여 접속 시, ID와 비밀번호 외에 추가인증(일회용 비밀번호를 활용한 2차인증 등)을 적용하여야 한다.

⑨사용하지 않거나 접속이 적은 국가에 대해서는 해외 접속 차단을 적용하며, 해외접속이 필요한 경우 가상 사설망(SSL VPN)등의 인가된 방법을 통하여 접속한다.

⑩개인정보 조회 시도 시 추가 승인 절차를 적용하여야 하며, 개인정보가 담긴 파일을 다운로드 할 경우 파일 비밀번호를 반드시 설정하여야 한다.

⑪관리자 페이지는 유추할 수 있는 도메인(admin, manager 등)을 지양하며, IP 또는 포트 기반 접근제어를 반드시 설정하여야 한다.

제76조 (로그 및 소스 관리) ①사용자 ID, 사용시간, 사용 정보, 로그인 실패 내역 등의 사용자 로그 정보는 최소 6개월 이상 보관 되어야 한다.

②시스템상의 로그파일과 백업된 로그파일은 수정이 가능해서는 안 된다.

③컴퓨터 범죄나 오용이 발생했다고 의심될 때 조사를 위해 필요한 관련 정보를 즉시 안전하게 확보해야 한다.

④정보보호담당관의 사전 승인이 없는 한 모든 어플리케이션의 로그는 비인가자가 접근할 수 없어야 한다.

⑤개발된 프로그램 소스는 실 운영 시스템에 저장되어서는 안되며 실 운영 시스템에는 실행 프로그램만을 저장 하여야 한다.

⑥프로그램 소스를 실 운영 시스템에서 컴파일해야 할 경우에는 프로그램 생성 후 삭제 하여야 한다.

⑦프로그램의 소스는 장애 등 비상시를 대비하여 운영환경이 아닌 별도의 환경에 저장 및 관리해야 하며 백업본에 대한 비인가자의 접근통제가 이루어져야 한다.

⑧중요한 변경이 필요한 경우 정보보호담당관의 승인을 득한 후 문서화된 양식을 통하여 변경 요청을 수행 하여야 한다.

⑨어플리케이션의 유지보수 및 변경 작업에 대해 정보보호담당관과 협의 후 수행하여야 한다.

⑩변경작업은 서비스 운영을 고려하여 업무이외의 시간에 변경 작업을 수행하여야 한다. 단, 긴급을 요하는 변경 작업의 경우 정보보호담당관의 승인을 득한 후 수행 할 수 있다.

⑪정보시스템에 다음 사항과 같은 변경이 이루어지는 경우 관리 소관부서의 장은 정보보호담당관에게 보안성검토를 의뢰하여야 한다.

1. 어플리케이션의 전면적인 수정
2. 인증, 암호화 등 보안 기능의 변경이 수반되는 경우
3. 새로운 위협, 취약성의 발견으로 정보시스템에 적용이 필요한 경우

⑫어플리케이션 변경에 관련된 사항은 문서화하여 관리하여야 한다. 문서화 내용에 다음의 사항을 포함하여야 한다.

1. 변경 요청 전, 후의 내용
2. 변경 방법
3. 변경 일시
4. 변경 수행 담당자

⑬중요정보 및 개인정보의 저장 위치(데이터베이스 및 테이블·컬럼명) 및 정보를 식별하고 지속적으로 현행화하여 관리하여야 한다.

제14장 정보보안시스템관리

제77조 (선정 및 설치) 정보보안시스템을 설치·운용하고자 하는 경우 아래와 같은 사항을 반영하여 선정하여야 한다.

1. 국내용 CC인증 제품이거나 국정원장이 그와 동등한 효력이 있다고 인정한 제품
2. 소관업무 및 정보통신망 특성을 지원할 수 있는 제품
3. 외부에 직접 서비스를 제공하거나 민감한 정보를 보관·처리하고 있는 웹, 데이터베이스, 응용 프로그램 등은 공용 장비로 사용하지 않고 독립된 서버로 운영하여야 한다.

제78조 (운용 및 보안관리) ①정보보호담당관은 정보보안시스템 운용 관리자로 ‘정보보안시스템 관리자’를 지정한다.

②정보보안시스템은 직접 연결된 단말기에서만 접속할 수 있도록 해야 한다. 단, 원격관리가 필요한 경우 지정된 단말기를 통해서 원격관리를 허용할 수 있다.

③침입차단시스템 등의 정보보안시스템 로그는 최소 6개월 이상 보관한다.

④정보보안시스템은 보안기능을 임의로 변경하거나 도입 목적이외의 용도로 운영하여서는 안 된다.

⑤시간 동기화가 정상적으로 이루어지고 있는지 주기적으로 점검하여야 한다.

제79조 (정보보안시스템 보안정책 등록, 변경, 삭제) ①정보보안시스템의 보안정책의 추가·수정 등이 필요한 경우, 관련 업무담당자는 정보보호담당관에게 승인을 받아야 한다.
 ②정보보안시스템관리자는 정보보호담당관의 승인을 득한 후 정책 변경작업을 수행하고, 보안정책 변경 내역을 '[별지 제11호 서식]보안규정 변경 관리대장'에 기록한다.
 ③정보보안시스템 관리자는 보안정책을 분기 1회 이상 점검하여, 사용기간이 지난 보안정책이나 취약한 보안정책은 삭제한다.

제15장 침해사고대응

제80조 (침해사고대응팀 구성) ①침해사고를 효과적으로 대응하기 위해서 침해사고대응팀을 구성하며, 침해사고대응팀은 침해사고 발생시, 한시적으로 운영한다.
 ②침해사고 발생시, 본교의 정보보안조직은 침해사고대응팀으로 전환되어 운영되며, 정보보호담당관은 필요에 의하여 분임정보보호담당관을 선임할 수 있다.
 ③침해사고대응팀의 팀장은 정보보호담당관으로 한다.
 ④침해사고대응팀의 실무 총괄은 정보보안담당자를 침해사고대응 담당자로 지정하고 침해사고 대응 및 보고업무를 총괄 수행한다.
 ⑤침해사고대응 책임관은 침해사고대응팀 및 유관기관 등의 연락처를 '침해사고 비상연락망'에 기록하고 현행화해야 한다.
 ⑥침해사고대응팀은 연 1회 이상 모의대응훈련을 실시하고, 그 결과를 기록 관리 하며, 훈련 결과를 바탕으로 개선사항을 도출하여 대응체계를 개선해야 한다.

제81조 (침해사고유형) 다음 각 호의 어느 하나에 해당하는 사항을 침해사고로 본다.

1. 비인가자의 정보시스템 접근
2. 정보자산의 유출(H/W, S/W, DATA 등)
3. 비인가자에 의한 중요 정보의 위·변조 및 삭제에 관한 사항
4. 악성 프로그램(바이러스, 백도어 등) 유포
5. 정보시스템에 대한 서비스 거부공격(DDOS 공격 등) 발생
6. 네트워크 장비, 서버 및 PC 등에 대한 해킹 발생
7. 어플리케이션에 대한 비인가 접근 발생
8. 그 밖의 정보보안사고 유형 [별표2]에 해당하는 사항

제82조 (침해사고 신고 및 접수) ①교내 구성원은 침해사고 등의 징후가 포착되거나 침해사고가 발생한 경우, 즉시 분임정보보호담당관 또는 정보보호담당관에게 신고해야 한다.
 ②정보보호담당관은 상시 모니터링을 실시하며, 침해사고 등 탐지 시 적절한 조치를 실시

해야 한다.

③침해사고 발생 시 신고자는 가장 빠른 방법을 통해 신고해야 하며, 정보보호담당관은 ‘[별지 제13호 서식] 침해사고 발생보고서’에 기록하여 문서상으로 보관 관리해야 한다.

제83조 (침해사고의 보고) ①정보보호담당관은 접수된 신고 사항에 대해 기록하고, 시정 조치가 종료될 때까지 모든 기록을 유지, 관리하며 조치된 내역에 대해 ‘[별지 제14호 서식] 침해사고 처리결과서’를 작성하여 정보보호책임관에게 보고해야 한다.

②보안담당관은 사고내역 및 조치내역을 확인하고 총장에게 보고한다.

③보안담당관은 홈페이지 변조, 침해사고로 인한 전산망 마비 또는 중요 정보자료, 개인 정보 유출 등 중대사고 발생 시에는 그 사실을 관계기관(고용노동부, 교육부, 국정원 등)에 보고한다.

④ 개인정보 침해사고 발생 시 관련 법령 개인정보보호 관련 법령에 따라 정보주체(이용자)에게 통지해야 한다.

제84조 (침해사고 대응 및 조치) ①정보보호담당관은 정보통신망에 대하여 해킹, 웜·바이러스 유포 등 사이버공격 인지 시 피해실태를 파악하고 관련 로그자료 보존 및 필요시 해킹된 정보시스템과 전산망 분리, 공격IP 및 포트의 차단 등 초동 조치를 취한다.

②홈페이지 변조, 전산망 마비 또는 중요 정보자료, 개인정보 유출 등 중대사고 발생 시에는 초동조치 후 즉시 관계기관(고용노동부, 교육부, 국정원 등), 외부전문업체 등에 통보하여 지원을 받을 수 있다. 이 경우 해당 피해시스템은 사고원인 규명 시까지 증거보전을 의무화하고 임의 자료삭제 또는 포맷을 하여서는 아니 된다.

③정보보호담당관은 응급조치 후 정보보안 침해사고의 원인분석 및 증거확보를 위하여 해당 침해사고 관련 로그 및 제반 증거 자료를 수집·확보 한다.

제85조 (침해사고 복구 및 재발방지) ①정보보호담당관은 전자적 침해사고로 인하여 소관 정보통신기반시설이 파괴되거나 기능이 제대로 수행되지 아니하는 때에는 해당 시설이 정상적으로 가동될 수 있도록 필요한 복구조치를 신속히 취하여야 한다. 이 경우 정보보호담당관은 관계 행정기관, 수사기관 및 외부 정보보안 전문업체에게 복구에 필요한 지원을 요청할 수 있다.

②정보보호담당관은 침해사고에 대한 복구가 완료된 경우, 유사사고 재발방지 대책을 수립하고, 대응·복구사항에 대한 교육 및 공지를 수행한다.

③정보보호담당관은 침해사고에 대한 복구 전까지 해당 시스템 또는 시설의 운영을 중단시킬 수 있다.

제16장 외주용역 보안관리

제86조 (계약 시 보안관리 등) ①정보화, 정보보안사업, 정보시스템 등을 외부 용역으로 외부업체와 계약할 경우에 계약서에 정보보안 준수 의무 및 위반할 경우에 손해배상 책임 등을 명시하여야 한다.

②계약서에 정보보안 준수 의무 및 위반에 대한 사항을 명시하는 경우 [별표3]의 내용을 참조 한다.

③외부 기관을 통하여 침해사고 대응체계를 구축·운영하는 경우, 침해사고 대응절차의 세부사항을 계약서에 반영해야 한다.

④개인정보 처리 업무를 위탁하는 경우, 동일한 수준의 기술적·관리적 보호조치를 이행하도록 관리·감독하여야 한다.

제87조 (참여인원 보안관리) ①사업주관부서는 모든 참여인원에 대하여 각 개인의 친필서명이 들어간 보안서약서를 징구해야 한다.

②사업주관부서 담당자는 사업 시작 전 참여인원에 대한 보안준수 의무 등의 보안교육을 실시하고, 교육 참가에 대한 자필서명을 받는다.

③사업수행시 사업수행업체의 대표자(PM)를 보안담당관으로 지정·운영하며, 사업수행업체 대표자(PM)는 사업전반에 대한 인원·장비·자료·정보 등을 관리하며 보안사고 방지를 위한 자체 활동을 수행해야 한다.

제88조 (자료에 대한 보안관리 등) ①전산망구성도, IP현황, 개인정보, 기타 용역업체에 제공하는 자료는 '[별지 제15호 서식] 자료관리대장'을 작성하여 인계자(본교 사업담당자)와 인수자(용역업체 사업수행대표)가 직접 서명한 후 인계·인수해야 한다.

②용역사업 관련자료 및 사업과정에서 생산된 모든 산출물은 본교의 파일서버에 저장하거나 정보보호담당관이 지정한 PC에 저장·관리한다.

③용역사업 관련 자료는 인터넷 웹하드 등 인터넷 자료공유사이트 및 웹 메일 등의 외부 메일함에 저장을 금지하고, 전자우편을 이용해 자료전송이 필요한 경우에는 본교 전자우편을 이용 하여, 첨부자료를 암호화(비밀번호) 후 수·발신 한다.

④본교와 관련된 자료를 출력물로 제공한 경우에는 시건장치가 된 보관함에 보관하여야 한다.

⑤사업수행업체는 사업수행으로 생산되는 산출물 및 기록은 본교의 해당사업 주관부서장 또는 정보보호책임관이 인가하지 않은 비인가자에게 제공·대여·열람을 금지한다.

제89조 (장비·사무실에 대한 보안관리) ①사업수행업체의 노트북, PC는 반입시 마다 최신의 바이러스 백신프로그램 설치와 바이러스 감염여부를 점검·확인해야 한다.

- ②반입된 노트북 PC는 사업 종료 시까지 반출을 금지한다. 다만 부득이하게 외부반출이 필요한 경우에는 최소한의 장비만 반출승인하고 자료유출에 대비한 보안조치(부팅·로그인 패스워드 설정, 자료 암호화 등)를 실시한 후 반출한다.
- ③USB 등의 보조기억매체 사용을 금지한다. 다만, 산출물작성 등 보조기억매체가 필요한 경우는 정보보호책임관의 승인 하에 허가된 것만 사용한다.
- ④용역사업 수행장소는 시건장치와 출입통제가 가능한 공간을 사용해야 한다.

제90조 (내·외부 정보망 접근에 대한 보안관리) ①용역사업 수행 시 정보시스템에 대한 사용자 계정(ID)이 필요한 경우, 외부인력에게 별도의 계정을 발급하고 접근권한을 부여 후 계정발급 및 접근권한 부여 기록을 별도로 관리 한다.

- ②외부인력에게 부여된 접속권한이 불필요한 경우 곧바로 권한을 해지하거나 계정을 삭제한다.
- ③프로그램 개발 용역사업 수행을 위한 작업은 사업수행업체의 자체 개발서버 또는 본교가 제공한 개발서버에서 수행함을 원칙으로 하며, 개발이 완료된 후 실 운영시스템에 설치하는 본교의 해당 시스템 담당자의 감독 하에 작업한다.
- ④용역업체 전산망에서 P2P, 웹 하드 등 인터넷 자료공유사이트로의 접속을 차단한다.

제91조 (사업완료시 보안관리 등) ①사업완료 후 생산되는 최종 산출물 중 대외보안이 요구되는 자료는 대외비로 작성·관리하고 불필요한 자료는 삭제 및 세단 후 폐기한다.

- ②용역업체에 제공한 제반자료, 장비, 서류와 중간·최종 산출물 등 용역과 관련된 제반 자료는 전량 회수하고 업체에 복사본 등 별도 보관을 금지한다. 단, 소스코드 등 향후 유지보수를 위해 필요하다고 판단되는 경우 정보보호책임관의 승인 후 용역업체에게 제공할 수 있다.
- ③사업완료시 용역업체의 노트북 PC 및 사용된 보조기억매체는 자료에 대하여 포맷 등 완전삭제 수행 후 반출한다.
- ④노트북·보조기억매체 등 전자적으로 기록된 자료는 복구할 수 없도록 삭제해야 한다.
- ⑤사업완료시 용역사업 관련자료 회수 및 삭제조치 후 업체에게 복사본 등 용역사업관련 자료를 보유하고 있지 않다는 대표 명의로 '[별지 제16호 서식] 보안확약서'를 징구한다.

제17장 개인정보보호

제92조 (개인정보보호) ①교내 구성원은 업무목적으로 개인정보를 수집, 이용, 저장하는 경우 개인정보가 유출되지 않도록 유의해야 한다.

- ②교내 구성원은 업무용도 외 개인정보를 사용·소지하지 않아야 하며, 업무상 알게 된 개

인정보를 침해 또는 누설하여서는 안된다.

③개인정보보안 및 CCTV운영·보안과 관련된 세부사항은‘개인정보 보호규칙’을 따른다.

제18장 보안성 검토

제93조(보안성 검토) ①각 부서의 장은 정보통신망, 서버, 홈페이지 등의 신·증설 등에 모든 정보화 사업에 대하여 보안대책을 강구하고 적절성 확인을 위하여 관련 사업 계획 단계에서(사업 공고 전) 정보보호담당관에게 보안성 검토를 의뢰하여야 한다.

②개인정보 처리시스템을 신규 개발, 고도화 또는 외부시스템과 연계하고자 하는 경우, 사업계획단계(보안성검토 요청 전)에서 개인정보보호규칙 제20조에 따라 개인정보 영향평가 및 개인정보파일 등록 대상 여부 등을 심사하여야 한다.

③정보보호담당관은 제1항과 제2항의 검토결과가 누락 또는 부적절한 사업에 대해서는 정보화사업 승인, 예산 배정 및 기술 검토를 보류할 수 있다.

④보안성 검토의 대상, 절차, 제출자료 목록, 보안대책에 포함해야 할 사항 등 구체적인 내용은 제94조를 따른다.

제94조(보안성 검토 대상) ①각 부서의 장은 다음 각 호의 정보화사업을 추진할 경우에 대하여 자체 보안대책을 강구하고 안전성을 확인하기 위하여 사업 계획단계(사업 공고 전)에서 정보보호담당관에게 보안성 검토를 의뢰하여야 한다.

1. 정보시스템 구축·개선
2. 내부 정보통신망을 인터넷이나 타 기관 전산망 등 외부망과 연동하는 경우
3. 업무망과 연결되는 무선 네트워크 시스템 구축
4. 스마트폰·클라우드 등 첨단 IT기술을 업무에 활용하는 시스템 구축
5. 원격근무시스템 구축
6. 업무망과 인터넷 분리 사업
7. 타 기관 정보시스템을 활용하여 업무를 처리하는 경우
8. 그 밖에 정보화추진위원회에서 보안성 검토가 필요하다고 판단하는 정보화사업

②정보보호책임관은 다음 각 호에 해당하는 정보화사업의 경우, 보안성 및 중복성 검토를 위해 정보화위원회에 심의를 요청할 수 있다.

1. 정보시스템 구축을 목적으로 하는 전략·계획 수립, 컨설팅 사업(BPR, ISP, ISMP 등)
2. 사업유형과 상관없이 SW개발비가 1억원 이상인 사업
3. 기타 정보보호책임관이 필요하다고 판단되는 사업

제95조(보안성 검토 절차) ①각 부서의 장은 보안대책을 자체적으로 수립한 후 정보보호담당

당관에게 보안성 검토를 요청한다.

②보안성 검토는 서면 검토를 원칙으로 하되 정보보호담당관이 필요하다고 판단하는 경우에는 현장 확인을 병행 실시할 수 있다.

③정보보호담당관이 필요하다고 판단하는 경우 정보화위원회 심의를 거쳐 사업의 적정성 및 보안성 검토를 추진할 수 있다.

제96조(제출 문서) ①각 부서의 장은 보안성 검토를 요청할 경우에는 다음 각 호의 문서를 제출하여야 한다.

1. 사업계획서(사업목적 및 추진계획 포함)
2. 기술제안요청서(RFP)
3. 자체 보안대책 강구사항

②제1항제4호의 자체 보안대책 강구사항에는 다음 각 호를 포함하여야 한다.

1. 보안관리 수행체계(조직, 인원) 등 관리적 보안대책
2. 정보시스템 설치장소에 대한 보안관리망 등 물리적 보안대책
3. 재난복구 계획 및 상시 운용계획

제97조(결과 조치) ①각 부서의 장은 정보보호담당관의 보안성 검토 결과를 준수하여 보안 대책을 보완하여야 한다. 이 경우, 정보보호담당관이 보안성 검토 결과 신속한 시정이 필요하다고 판단하는 경우에는 필요한 조치를 요청할 수 있으며 해당 부서의 장은 특별한 사유가 없는 한 이에 따라야 한다.

②정보보호담당관은 보안대책이 적절히 수립되었는지 등 이행여부 확인을 위하여 현장점검을 실시할 수 있다.

③보안성 검토 결과에 의한 사항이 수정되지 않았거나, 보안성 검토가 이루어지지 않은 상태로 사업이 시행된 경우에는 정보보호담당관은 시정 전까지 해당 사업 또는 시스템·시설의 운영을 중지시킬 수 있다.

제98조(보안성 검증) 정보보호담당관은 필요하다고 판단되는 경우, 보안성 검토 요청 자료를 바탕으로 고용노동부 또는 국가정보원에 보안성 검증을 의뢰할 수 있다.

제19장 클라우드 보안

제99조(클라우드 서비스 유형에 따른 역할 및 책임) ①클라우드 서비스 제공자와 정보보호 및 개인정보보호에 대한 책임과 역할을 명확히 정의하고, [별표 6]을 참고하여 서비스

제공자와 이용자의 역할 및 책임을 계약서에 반영하여야 한다.

제100조(클라우드 서비스 이용) ①클라우드 서비스 이용 시 서비스 유형에 따른 보안위험을 평가하여 비인가 접근, 설정오류 등을 방지할 수 있도록 하여야 한다.

② 정보보호담당관은 다음 각 호의 내용을 클라우드 서비스 유형에 따른 특성을 반영하여 수립·이행하여야 한다.

1. 보안 관리 역할 및 책임
2. 가상네트워크 보안 구성 및 접근통제
3. 클라우드 서비스 관리자 계정 및 권한 관리(최고관리자 및 분야별 관리자 등)
4. 클라우드 서비스 관리자에 대한 강화된 인증(일회용 비밀번호를 활용한 2차인증 등)
5. 보안 설정 기준(인증, 암호화, 세션관리, 접근통제, 공개설정, 장기미사용 잠금, 로그 기록, 백업 등)
6. 보안 설정 등록·변경·삭제 절차(신청, 승인 등)
7. 보안 구성 및 설정에 대한 적절성 검토
8. 클라우드 관리콘솔에 대한 접근통제 및 권한 관리 절차
9. Access Key의 발급, 이용, 회수 등에 대한 관리 절차
10. 클라우드 서비스 원격접속 경로 및 방법(가상 사설망, IP 주소 접근 제어, 2차 인증 등)
11. 클라우드 서비스 보안 관제 및 알람·모니터링 방안
12. 보안감사 절차

제101조(클라우드 서비스 관리자 권한) ①클라우드 서비스 관리자 권한은 역할에 따라 최소화하여 부여하고, 관리자 권한에 대한 비인가 접근, 권한 오·남용 등을 방지할 수 있도록 강화된 인증, 암호화, 접근통제, 감사기록 등 보호대책을 적용하여야 한다.

제102조(클라우드 서비스 보안 점검) ①클라우드 서비스에 대한 승인받지 않은 환경설정 및 보안설정 변경을 적발할 수 있도록 알람 설정 및 모니터링하여야 한다.

② 클라우드 서비스 보안설정의 적정성 여부를 정기적으로 검토 및 조치하여야 한다.

제20장 보칙

제103조(다른 법령과의 관계) 이 규칙에 명시되지 않은 사항은 「고용노동부 정보보안 기본지침」을 따른다.

부 칙

제1조(시행일) 이 규칙은 2018. 1. 11.부터 시행한다.

제2조(다른 지침의 폐지) 정보자산 보호지침을 폐지한다.

부 칙(제1차 개정, 2023. 6. 1.)

제1조(시행일) 이 규칙은 2023. 6. 1.부터 시행한다.

부 칙(제2차 개정, 2023. 12. 13.)

제1조(시행일) 이 규칙은 2023. 12. 11.부터 시행한다.

부 칙(제3차 개정, 2025. 06. 01.)

제1조(시행일) 이 규칙은 2025. 06. 01.부터 시행한다.

부 칙(제4차 개정, 2026. 07. 01.)

제1조(시행일) 이 규칙은 2026. 07. 01.부터 시행한다.

【별표 1】 어플리케이션 보안기능 요건

어플리케이션 보안기능 요건

분류	보안기능 검토항목	Y	N	P	N/A
요건정의	주요 정보보호와 관련된 요건의 정의				
계정 관리	1인 1계정 원칙의 적용				
	퇴직자의 계정과 동일한 계정의 사용금지				
	응용시스템 패키지 사용 시 벤더 계정(Default 계정)의 사용금지				
	사용자 계정의 해당 응용시스템 내 유일성				
	개발자 계정의 운영환경 이관 시 제거				
	유추가 어려운 관리자 계정의 사용 (admin, root, master 등의 사용 지양)				
패스워드 관리	초기 패스워드의 변경강제 기능				
	패스워드 사용기간의 제한				
	패스워드 재사용 금지(최근 패스워드 2개 이상)				
	로그인시 패스워드의 평문 표시 금지				
	패스워드 사용규칙 준수여부 체크 - 계정과 동일하지 않을 것 - 영문, 숫자 조합으로 9자리 이상				
	패스워드의 연속 3회 입력 실패 시 계정사용 제한				
	패스워드의 암호화 저장				
	패스워드 분실 시 관리자의 초기화 기능				
	데이터베이스 접속 계정 및 패스워드의 소스코드 내 암호화				
로그인 절차	로그인 화면에 최소의 정보만 표시				
	로그인 실패에 대한 세부 원인 표시 금지				
	로그인 화면에 불법접속 금지 등 보안권고문 공지				
사용자 인증	사용자 인증 후 응용시스템의 사용 가능				
	인증항목으로 IP Address의 체크				
	사용자 인증강화를 위한 추가적인 인증기능 (공인인증서, 기타 2차적인 인증 수단 등)				
관리자 인증	관리자 모듈을 일반 사용자 모듈과 분리하고, 별도로 관리자 인증				
	유추가 어려운 관리자 페이지의 사용 (/admin, /manager, /master 등의 사용 지양)				
	관리자 페이지에 대한 접근제어 적용(IP 또는 포트 등)				
접근권한	사용자의 접근권한 수준에 따라 화면단위 접근통제				
	동일한 계정의 다중 접속 제한				
	일정 시간 경과 시 자동 로그아웃(세션차단)				
입력유효성	입력 데이터에 대한 무결성 체크				

검증	- 데이터 유형 (문자열, 정수형, 실수형 등) - 허용된 문자셋 (character set) - 최대 / 최소 길이 - Null 값의 허용 여부 - 반드시 필요한 인자와 그렇지 않은 인자 - 중복 허용 여부 - 숫자의 범위 - 지정된 범위의 값(enumeration) - 특정한 패턴(regular expressions)				
	SQL Injection 예방을 위한 입력값 필터링 - 사용자의 특수문자 입력시 예러처리 (‘ ’ “ ” / \ ; : Space - + 등)				
	Cross Site Scripting 예방을 위한 입력값 필터링 - 입력값 인코딩 < → < > → > (→ () →) # → # & → &				
	스크립트 파일에 대한 업로딩 제한 - 업로드 가능한 파일의 확장명 정의 및 업로드 허용 (반드시 Server Side Script에서 구현해야 함) - asp, aspx, cgi, jsp, java, cfm, php, ph 등 실행 가능한 파일의 확장명 업로드 금지				
	파일 다운로드 취약점의 예방				
로깅 관리	향후 감사추적을 위해, 중요 정보의 조회(수정, 출력) 시 로깅				
	로그 자료에 대한 적절한 수준의 접근통제				
	로그 자료의 일정기간 이상 보관				
	관리자의 활동에 대한 로깅				
암호화 통신	중요 정보의 통신시 암호화				
	클라이언트와 서버간의 암호화(전자상거래 혹은 대금 결제)				
암호화 저장	암호화에 필요한 주요 정보의 정의 및 데이터베이스 저장 시 암호화				
	비밀번호 등은 단방향 암호화				

【별표 2】 정보보안사고 유형

정보보안사고 유형

조	내 용	항	세 부 사 항
1	정보통신실 및 정보통신 시스템	(1) (2) (3) (4)	정보통신망에 대한 해킹·악성코드의 유포 비밀이 저장된 컴퓨터 분실 승인 없이 정보통신시스템내 비밀 저장 정보통신시스템 및 정보통신실 파괴
2	암호장비	(1) (2) (3) (4) (5) (6)	암호장비 분실 및 피탈 암호장비 파기 및 임의 파기 암호장비의 복제·복사 비인가 암호장비 사용 암호장비 비닉체계 특성 및 제원 노출 암호장비 키 운용체계 노출
3	암호 및 음어·약호자재	(1) (2) (3) (4)	암호·음어·약호자재의 분실 및 누설 암호·음어·약호자재의 파손 및 임의파기 암호·음어·약호자재의 임의제작 사용 세부 비닉체계 노출
4	정보자료	(1) (2) (3) (4) (5)	주전산기·대용량 전자기록(DB) 손괴 비밀자료의 유출·파괴·변조 및 평문 소통 전자공문서 위조 개인정보파일 공유 및 노출·유출 홈페이지 정보 유출·변조
5	정보보호 시스템	(1) (2)	정보보호시스템 보안기능 변경사용 암호프로그램이 내장된 정보보호시스템 분실·피탈

【별표 3】 용역사업 계약 시 정보보안 준수 및 의무 사항

용역사업 계약 시 정보보안 준수 및 의무 사항

1. 정보자산의 기밀성, 무결성, 가용성 보장

가. 한국기술교육대학교 정보자산을 허가 없이 외부 또는 제3자에 공개 및 유출하지 말아야 하며, 특히 업무 수행 시 취득한 정보를 다른 협력회사 등에 유출되지 않도록 주의한다.

나. 한국기술교육대학교 정보자산을 무단으로 변경하지 말아야 하며, 정확하고 완전한 상태로 유지한다.

2. 보안 관련 법적조항 및 보안규정 및 지침 준수 책임

가. 공공기관 개인정보보안에 관한 법률 등의 법적인 요구사항을 준수한다.

나. 정보보안 관련 법률에서 금지하고 있는 한국기술교육대학교 시스템 및 정보통신망에 대한 해킹 및 침해행위를 금한다.

다. 한국기술교육대학교 정보보안 관련 규정을 숙지하여 위반사항이 발생하지 않도록 준수한다.

라. 한국기술교육대학교 지적 재산에 대한 보호의무를 성실히 준수한다.

3. 계약 완료 시 정보자산 반환 및 폐기 의무

계약 완료 시 정보자산의 반환 및 폐기는 해당 사업의 한국기술교육대학교 책임자에 의해 확인되어야 한다.

4. 바이러스 확산 방지

가. 한국기술교육대학교 교내로 반입되는 모든 장비에는 반드시 백신이 설치되어 있어야 하며, 바이러스 검역 과정을 거친 후 한국기술교육대학교 교내 네트워크에 연결할 수 있다.

나. 수시로 반·출입되는 장비에 대한 관리 책임은 협력회사 측에 있으며, 백신의 정상 작동 여부 와 바이러스 엔진의 업데이트 여부를 반드시 확인한다.

다. 한국기술교육대학교 교내망에 연결된 상태로 E-mail을 이용하거나 인터넷을 통한 자료를 다운로드 받는 경우 반드시 바이러스 점검을 수행한다.

5. 보안위반사항 발생 시 책임

보안요구사항 및 계약서상에 명시된 준수사항 불이행으로 인해 한국기술교육대학교에 피해가 발생한 경우 보상 책임은 용역회사 측에 있으며, 현재 사업 및 향후 계약에 불이익이 발생할 수 있다.

6. 보안사고 보고 및 조사 동의

용역업체 참여직원은 한국기술교육대학교 내에서 사업 수행 중 보안사고 발견 시 신속히 해당사항을 한국기술교육대학교에 보고하여 지속적인 업무 활동이 보장될 수 있도록 협조한다.

7. 보안감사 수용

가. 용역업체 참여직원은 한국기술교육대학교 정보보안 관리규정 준수 현황 감독을 위해 한국기술교육대학교는 정기적으로 보안감사를 실시할 수 있는 권한이 있으며, 용역회사는 이에 적극적으로 협조한다.

나. 한국기술교육대학교의 핵심 정보시스템 또는 기밀 정보를 다루는 업무를 수행하는 협력회사 직원에 대해서 E-mail 모니터링 등의 물리적, 논리적 모니터링을 실시할 수 있다.

8. 기타 사항

가. 한국기술교육대학교 출입 시 반드시 허가된 지역만 출입한다.

나. 사업 수행을 위해 한국기술교육대학교 내부 시스템에 대한 사용 권한을 부여 받은 경우 용역 회사 직원은 부여받은 계정 및 패스워드가 노출되지 않도록 각별히 주의한다.

【별표 4】 백업대상, 주기 및 보관주기

백업대상, 주기 및 보관주기

백업대상	권장백업주기	최소 보관주기
OS, DBMS, 기타 시스템 S/W	월간	6개월
핵심업무 및 중요업무 데이터(민원고객 관련 데이터)	일일, 주간, 월간	6개월
일반업무 데이터(한국기술교육대 내부 업무 처리관련 데이터)	주간, 월간	6개월
정보보안관련 데이터 (방화벽 정책, 로그 파일)	일일, 주간, 월간	6개월
네트워크 관련 데이터 (라우터, 스위치 구성파일)	환경설정 변경이전, 분기	6개월

【별표 5】 내부감사 점검항목

내부감사 점검항목

1. 정보보안 관리규정

구분	점검항목
지침/매뉴얼 관리	주기적으로 정보보안 관리규정 및 지침을 검토하여 변경사항 발생 시 개정하였는가?
	정보보안 관리규정 및 지침 개정 시 관련담당자들에게 개정 내용을 전달하였는가?
정보보안 업무 계획	보안업무 세부추진 계획을 수립하였는가?
보안 심의	보안심사 위원회에 심의를 요구한 경우 관련 문서들을 보관하고 있으며, 심의 결정사항을 이행하고 있는가?
운영검토	정보보안 관리체계 운영검토를 실시하였는가?

2. 정보보안 관리체계 내부감사 매뉴얼

구분	점검항목
계획 및 이행	연간 내부감사 계획을 수립하고 이행하였는가?
결과 보고 및 시정	이전 내부감사 지적사항을 이행하였는가?
	내부감사 결과를 정보보호책임관에게 보고하였는가?
	내부감사 결과 지적된 사항에 대한 시정조치계획을 수립하였는가?
	시정조치계획에 따라 이행하였는가?

3. 침해사고 대응 매뉴얼

구분	점검항목
침해사고 대응	침해사고 발생시 발견자는 침해사고 신고서를 작성하여 신고하였는가?
	침해사고 대응을 위해 지식정보보호 전문업체에 기술지원을 요청했을 경우, 보안서약서를 징구하였는가?

	발생된 침해사고에 대한 사고 분석을 실시하였는가?
	중대한 침해사고가 발생되었을 경우, 침해사고 대응센터를 운영하였는가?
사후 관리	동일한 침해사고가 발생되지 않도록 교육 및 감시 활동 등의 사후관리를 수행하였는가?

4. 정보자산 및 위협관리 매뉴얼

구분	점검항목
자산 관리	정보자산의 변경사항이 발생한 경우 정보자산 관리 목록을 갱신하였는가?
	응용시스템 및 서버를 대상으로 연1회 자산 중요도 평가를 수행하였는가?
	등록된 정보자산에 대하여 라벨을 부착하였는가?
위험분석	연1회 위험분석을 실시하였는가?
	각 팀장은 위험분석 결과를 바탕으로 하여 수용 가능한 위험의 수준(DoA)을 정하고 관리대상 위험을 식별하였는가?
	정보보호대책 명세서 및 단계별 위협관리 방안을 작성하였는가?
	정보보호 적용성 보고서를 작성하여 관리하고 있는가?

5. 외주 보안관리 매뉴얼

구분	점검항목
일반사항	제3자 및 외부위탁 계약 시 계약서 등에 보안 요구사항을 반영하여 체결하였는가?
	참여인원의 친필서명이 들어간 보안서약서를 징구하였는가?
내부자료 보안	제공된 내부자료에 대해 자료관리대장을 작성하여 관리하고 있는가?
	업무 수행을 위해 제공하는 내부 자료를 안전하게 보관하고 있는가?
장비 보안관리	참여인원의 PC 반입 시 바이러스 백신 프로그램 설치 및 바이러스

	감염여부를 확인하였는가?
	반입된 PC는 업무 종료 시까지 반출되지 않도록 통제하고 있는가?
	사용자 계정은 하나의 그룹으로 등록하고 사용자 계정별로 정보시스템에 접근권한을 부여하였는가?
	사용자 계정별로 부여된 권한은 불필요 시 곧바로 권한을 해지하거나 계정을 폐기하였는가?

6. 정보보안 교육훈련 매뉴얼

구분	점검항목
계획 수립	연간 정보보안 교육계획을 수립하였는가?
기본교육 실시	각 팀장은 팀원들을 대상으로 분기별 1회 이상 정보보안 기본교육을 실시하고 있는가?
	각 팀장은 신규직원에게 대해 발령 후 1개월 이내에 정보보안 기본교육을 실시하는가?
	외주업체 인원에 대해서 용역 실시단계에서 필요한 정보보안 기본교육을 실시하는가?
전문교육 실시	정보보안 전문교육을 실시하였는가?

7. PC/LAN사용자 보안 매뉴얼

구분	점검항목
PC 관리	개인소유 등 인가 받지 않은 PC가 반입되어 있는가?
	반출된 PC(노트북)에 대해 중요자료를 백업 후 제거하여 반출하며, '전산장비 반출입대장'에 관련 내용을 기록하였는가?
	파일 및 디렉토리 공유설정을 금지하였는가? 부득이 공유설정 시 암호설정 후 사용하고 있는가?
	PC 부팅 시 CMOS 패스워드를 설정하고 있는가?
	PC 로그인 및 화면보호기에 암호를 설정하고 있으며, 화면보호기 대기 시간은 10분 이하로 설정되어 있는가?
	백신 프로그램이 설치되어 있으며, 최신버전으로 유지하고 있는가?

	최신 윈도우 보안 패치를 설치하였는가?
	PC내에 비밀번호가 저장되어 있는가?
	PC에 불법 소프트웨어가 설치되어 있는가?
	사용자는 월1회 바이러스, 불법 소프트웨어 설치 유무를 점검하고 있는가?
LAN 사용 통제	외부 사용자가 LAN 사용 시 'LAN 사용신청서'와 'LAN 사용 보안 서약서'를 작성하여 분임정보보호담당관 에게 제출하였는가?
데이터 백업	필요한 데이터는 적절하게 백업하고 있는가?
	데이터 백업매체는 시건 장치가 되어 있는 장소에 보관하고 있는가?

8. 응용시스템 보안관리 매뉴얼

구분	점검항목
개발 및 운영의 분리	개발 및 테스트 시스템과 운영시스템은 분리되어 있는가?
	개발에 필요한 도구가 운영환경에 설치되어 있지 않은가?
요구사항 분석	시스템의 도입 및 개발 발주 시 중요도에 따라 보안기능 요구사항을 검토 후 반영하였는가?
	보안기능을 반영하여 요구사항을 분석하고, 설계하고 있는가?
보안 기능의 설계	응용시스템 관리자 모듈과 사용자 모듈을 분리하고 별도의 관리자 인증을 수행하고 있는가?
	응용시스템 관리자 모듈의 사용자 계정 및 비밀번호 입력이 3회에 걸쳐 일치하지 않을 때 해당 접속을 중지시키고 비인가자 침입 여부를 확인할 수 있도록 설계되어 있는가?
	패스워드 생성기준은 숫자와 문자 등으로 9자리 이상으로 정하고 주기적으로 변경하도록 설계되어 있는가?
	모든 입력 데이터에 대하여 유효성 점검을 수행하도록 설계되어 있는가?
	화면상에 패스워드와 같은 민감한 데이터가 평문으로 보이지 않도록 되어 있는가?
	비밀성을 요하는 데이터는 암호화하여 저장하고 있는가?
	중요한 응용시스템의 경우 관리자와 사용자의 중요한 활동에 대한 감사 로그를 생성하고 있는가?

응용시스템의 테스트	응용시스템 테스트 시 임의의 테스트 데이터를 생성하여 활용하거나 운영 데이터를 가공하여 사용하며, 실제 운영 데이터의 사용을 금하고 있는가?
	입력데이터의 유효성 점검을 실시하고 있는가?
응용시스템의 설치	응용시스템의 설치 시 테스트 시나리오를 작성하여 승인을 득하였는가?
응용시스템의 변경 관리	응용시스템의 변경사항이 발생한 경우 변경 요청서를 작성하여 응용시스템 관리 팀장에게 변경을 요청하였는가?
	변경 요청의 타당성 검토 후 변경하고 관련 내용을 기록하고 있는가?
	긴급한 상황 하에서 승인절차를 생략하고 응용시스템을 변경한 경우 사후 승인을 득하였는가?
소스 관리	프로그램 소스는 운영중인 시스템에 저장하여 관리하는 것을 금하고 있는가?
	프로그램 소스 접근을 통제하고 접근기록을 남기고 있는가?
	개발 중이거나 유지보수 중인 프로그램은 운영 중인 프로그램의 소스와 분리하여 관리하고 있는가?
계정 및 권한관리	사용자 계정의 등록(신규, 추가, 변경, 삭제 등) 사유가 발생할 경우 양식을 이용하여 신청하고 있는가?
	사용자 계정에 대해 사용자 ID 관리 대장에 기록하고 있는가?
	분기별로 사용자 계정에 대해 재확인을 실시하여 삭제, 중지, 등록 등 필요한 조치를 취하고 있는가?
	퇴직자 및 전출자의 계정을 적시에 삭제하고 있는가?
	응용시스템 사용자들의 권한관리를 실시(정기적 권한의 적절성 검토)하고 있는가?
	응용시스템 접속 한 후 일정시간 동안 어떤 입력도 일어나지 않을 경우 자동적으로 세션을 중단시키도록 해당 시스템을 설정하고 있는가?
백업	소스 파일을 변경 시마다 백업하여 안전한 장소에 보관하고 있는가?
모니터링	응용시스템이 처리하는 중요정보에 대한 접근 기록을 3개월 이상 보관하고 있는가?
취약점 점검	외부 응용시스템의 이관 시에 수시 취약점 점검을 실시하고 있는가?

	종합점검 및 수시점검 시 발견된 취약점에 대하여 보완계획을 수립하고 이행하였는가?

9. 서버 보안관리 매뉴얼

구분	점검항목
신규 도입	서버 신규 도입 시 보안성 검토를 요청하고, 결과에 따라 조치하였는가?
	신규로 도입 설치되는 서버시스템에 취약점 점검을 실시하고, 발견된 취약점을 조치토록 하였는가?
	취약점 조치 권고안에 따라 조치가 불가하거나 불가피하게 적용되어야 할 사항에 대해 보안규정 예외적용신청서를 작성하였는가?
소프트웨어의 설치	서버에 설치된 소프트웨어의 현황을 관리하고 있는가?
	업무 목적 외 또는 불법 소프트웨어는 설치되지 않았는가?
	원격관리 소프트웨어 설치에 대한 보안대책을 수립하고 승인을 받았는가?
보안설정	서버에 주기적으로 보안 패치 및 보안설정을 적용하고 있는가?
	모든 서버는 로그인을 허용하기 전에 보안권고문을 공지하고 있는가?
계정 생성 및 관리	사용자 계정의 등록(신규, 추가, 변경, 삭제 등) 사유가 발생할 경우 양식을 이용하여 신청하고 있는가?
	사용자 계정 생성 절차 및 규정을 따르고 있는가?
	서버 사용자 계정에 대해 사용자 ID 관리 대장에 기록하고 있는가?
	기 사용된 계정은 최소 1년 동안 다른 사용자에게 재부여하지 않는가?
	디폴트 계정은 삭제하였는가? 예외로 사용 시 패스워드를 변경하였는가?
	60일 이상 사용자 계정이 사용되지 않을 경우 일시 중지시키며, 일시 중지된 후부터 60일간 사용요청이 없는 경우 계정을 삭제하고 있는가?

	분기별로 사용자 계정에 대해 재확인을 실시하여 삭제, 중지, 등록 등 필요한 조치를 취하고 있는가?
	퇴직자 및 전출자의 계정을 적시에 삭제하고 있는가?
패스워드 생성 및 관리	패스워드 길이는 최소 9자 이상인가?
	접근시도 패스워드가 3회 이상 일치하지 않을 경우 접속이 거부되고 있는가?
	사용자가 패스워드를 사용할 수 있는 최대기간(1회/1월) 및 사용해야 하는 최소기간(1일)을 설정하고 있는가?
	사용자가 과거에 사용했던 패스워드를 최소 6개월 이내에 사용하지 못하도록 하고 있는가?
	패스워드는 암호화되어 저장되며, 화면에 읽을 수 있는 형태로 표시되지 않고 있는가?
	서버관리자에 의해 부여된 초기 패스워드는 사용자가 처음 접속 시 자신의 패스워드로 변경하도록 강제화하고 있는가?
권한 관리	사용자 접근권한 신청 및 검토 절차를 준수하였는가?
	일반사용자의 타 사용자 디렉토리 등에 대한 접근권한 제한을 하였는가?
	일반사용자에게 관리자 권한을 부여하지 않았는가?
접근통제	중요 서버 접근 시 SSH 등 암호화된 통신 프로토콜을 사용하는가?
	로그인 화면에서는 로그인 관련 정보외의 정보를 보여주지는 않는가?
	로그인 실패 시 시스템 침해의 원인이 될 정보를 보여주지는 않는가?
	로그인 성공 시 최근 접속 시간, 날짜, 터미널 등의 정보를 보여주는가?
	서버에 접속한 후 사용자나 다른 시스템으로부터 일정시간 동안 어떤 입력도 일어나지 않으면 자동적으로 로그오프 시키거나 세션을 중단시키고 있는가?
	통제구역 이외의 장소에 설치된 서버에 화면보호기가 설정되어 있는

	가?
	시스템 관리자들이 원격접속을 수행하고 있는가? 원격접속시 안전한 방법으로 로그인 및 통신하고 있는가?
	업무상 불필요한 서비스는 제거하였는가?
패치/시스템 파라미터 관리	패치나 시스템 파라미터를 변경할 때 그와 관련된 모든 사항에 대한 기록을 남기고 있는가?
백신 설치 및 운영	윈도우 서버의 경우 바이러스 백신이 설치되고, 최신 업데이트가 되어있는가?
	바이러스 감염 시 담당자에게 신고 등의 절차를 준수하는가?
무결성 점검	시스템 무결성을 검증하는 툴을 이용하여 정기적으로 시스템에 대한 무결성을 검토하고 있는가?
인터넷 서버 운영	웹서버와 메일서버는 분리해서 운영하고 있는가?
취약점 점검	년1회 이상 취약점에 대한 종합점검과 수시점검을 실시하고 있는가?
	점검 결과 발견된 취약점에 대한 보완계획을 수립하여 이행하는가?
	단기 조치가 어려운 취약점에 대하여 사유를 기록, 관리하는가?
로그관리	침해사고 발생시 추적성을 확보하기 위해 로그를 남기고 있는가?
	모든 서버들의 내부시각이 일치하는가?
	시스템 접속 로그는 최소 3개월 이상 보관하고 있는가?
백업 및 매체 관리	백업계획에 따라 백업을 수행하고 있는가?
	백업 매체는 비인가자가 접근할 수 없도록 격리되어 보관하는가?
	백업매체의 폐기 시 승인을 얻고 소각하는가?
운영 및 폐기	데이터센터 SOP에 따라 성능/용량/장애/변경관리가 이루어지고 있는가?
	철수 또는 폐기 시 자료가 유출되지 않도록 보안대책을 강구하였는가?

10. 데이터베이스 보안관리 매뉴얼

구분	점검항목
----	------

보안설정의 적용	OS상의 사용자 계정 및 파일시스템의 접근제어를 설정하였는가?
	불필요한 디폴트 계정은 삭제하였는가? 필요 시 패스워드를 변경하였는가?
	DBMS에 대한 취약점 제거 및 패치를 수행하는가?
계정관리	서비스 제공을 위한 ID 이외에 ID를 공동으로 사용하지 않고 있는가?
	ID 신청 시 '사용자 ID 등록/삭제/권한변경 요청서'를 작성하여 신청하고 있는가?
패스워드 관리	패스워드 길이는 최소 9자 이상인가?
	접근시도 패스워드가 3회 이상 일치하지 않을 경우 접속이 거부되고 있는가?
	사용자가 패스워드를 사용할 수 있는 최대기간(1회/1월) 및 사용해야 하는 최소기간(1일)을 설정하고 있는가?
	사용자가 과거에 사용했던 패스워드를 최소 6개월 이내에 사용하지 못하도록 하고 있는가?
	패스워드는 암호화되어 저장되며, 화면에 읽을 수 있는 형태로 표시되지 않고 있는가?
	서버관리자에 의해 부여된 초기 패스워드는 사용자가 처음 접속 시 자신의 패스워드로 변경하도록 강제화하고 있는가?
	서비스 특성상 취약한 패스워드를 사용할 경우 보안규정 예외적용 신청서를 작성하여 서버시스템 운영팀장에게 제출하고 있는가?
사용자 ID의 등록 및 삭제	신규 ID 등록 시 요청서의 접수, 검토 등의 절차를 준수하는가?
	사용자 ID의 등록 삭제 시 'DBMS 사용자 현황'을 작성하여 관리하는가?
접근권한	DB 사용자를 데이터 갱신이 가능한 사용자와 조회만 가능한 사용자로 구분하여 운용하고 있는가?
	DB 설계자와 DB 관리자의 임무가 분리되어 있는가?

접근통제	DBMS 설치 소프트웨어 라이브러리 또는 DB 운영체제 파일의 변경은 DB 관리자만이 가지고 있는가?
	DBMS가 제공하고 있는 유틸리티 프로그램의 사용권한은 DB 관리자로 제한하고 있는가?
	데이터베이스 업무팀의 장은 데이터베이스 갱신 유틸리티(isql, dbaccess, sqlplus 등)의 사용을 작업의뢰서에 의해서만 허락하며 작업 내역을 일일 관리하고 있는가?
	사용자에게 부여된 권한을 주기적으로 재평가 하고 있는가?
	DB에 대한 추가 접근권한이 필요한 자는 '사용자 ID 생성/권한변경/삭제 요청서'를 작성하여 의뢰하고 있는가?
백업 및 복구	주기적으로 백업 및 소산하고 있는가?
	DB 장애 발생시 DBMS 장애 내역 보고서를 작성하여 보고하고 있는가?
	DBMS 복구 테스트를 주기적으로 실시하고 있는가?
로그관리	DB 보안관련 사항에 대한 로그를 저장하고 있는가?
운영관리	DB 운영과 관련하여 DB 월별 현황, 장애보고서, 유지보수 업체 작업일지, DBA 지원 비상연락망 등을 작성하고 있는가?

11. 네트워크 보안관리 매뉴얼

구분	점검항목
도입	네트워크 시스템 신규 도입 시 필요할 경우 성능 시험을 실시하고 있는가?
운영절차	네트워크 시스템은 보호구역에 설치되어 있는가?
	IP별 접근제어 정책을 구성하여 일반 사용자가 시스템에 접근할 수 없도록 보안 설정을 적용하고 있는가?
	시스템 로그인을 허용하기 전에 보안 권고문을 공지하고 있는가?

	네트워크 계정 등록, 변경, 삭제 시 '사용자 계정 생성/권한변경/삭제 요청서'를 작성하여 신청하고 있는가?
	네트워크 시스템간의 시간을 동기화 하고 있으며, 주기적으로 이를 점검하고 있는가?
접근통제	로그인 전에 불법사용에 대한 경고 메시지를 제시하고 있는가?
	사용자에게 부여된 권한을 월1회 이상 재확인하여 조치하고 있는가?
	연속적으로 3회 이상 패스워드를 잘못 입력할 경우 세션을 차단시키고 있는가?
	시스템 관리자들이 원격접속을 수행하고 있는가? 원격접속시 안전한 방법으로 로그인 및 통신하고 있는가?
무결성 점검	월 1회 이상 구성정보(Configuration)을 검토하며, 네트워크 시스템 구성정보에 대한 백업을 실시한 후 시스템에 대한 무결성을 검토하고 있는가?
패치 및 구성정보 변경통제	패치나 시스템 파라미터를 변경할 경우 관련 기록을 남기고 있는가?
	구성정보나 네트워크 시스템을 변경할 경우 '네트워크 시스템 환경 설정 변경 보고서'를 작성하여 팀장 승인 하에 작업을 수행하는가?
	네트워크 시스템 로그 정보를 정기적인 시스템 백업 시 함께 백업하고 1년 이상 보존하고 있는가?
취약점 점검	년 1회 이상 정기적으로 취약점 점검을 실시하고, 조치사항을 이행하고 있는가?
시스템 성능관리	네트워크 시스템에 대한 성능을 주기적으로 검토하여 보고서를 작성하고 있는가?
백업 및 매체관리	네트워크 시스템 구성정보에 대한 백업을 실시하고 있는가?
장애관리	장애 발생시 장애 내역 보고서를 작성하여 팀장에게 보고하고 있는

	가?
--	----

12. 정보보안시스템 운영 매뉴얼

구분	점검항목
접근통제	정보보안시스템은 콘솔에서 직접 작업을 하며, 모뎀을 연결해서 직접 접속하거나 인터넷 등 외부에서 원격 접속하는 것을 금지하고 있는가?
	원격관리가 필요한 경우 팀장의 승인을 받아 분임정보보호담당관 에 통보하였는가?
	정보보안시스템 고유의 서비스와 자체 보안을 강화하기 위한 응용 프로그램만 운영하고 있는가?
	업무상 사용자 계정 등록이 필요한 경우 '정보보안시스템 사용자 계정 등록/변경/재발급/삭제 요청서'를 작성하여 사용자를 등록하고 있는가?
보안정책	룰셋을 등록, 변경할 필요가 있는 경우 '정보보안시스템 Rule 등록 (변경/삭제) 요청서'를 작성하여 적용하고 있는가?
	분기별 1회 이상 정보보안시스템 보안정책을 점검하여 사용하고 있지 않거나 사용기간이 경과된 룰셋을 삭제하고 있는가?
	패킷필터링 관리대장, 서비스 관리대장, 침입차단시스템 점검관리 대장, 상세 연결내용을 포함한 구성도, 침입차단시스템 제품 및 버전, 운영체제명 및 버전 등을 문서화하여 보관하고 있는가?
로그 및 백업	정보보안시스템의 로그를 매일 분석하여 그 결과를 보관하고 있는가?
	구성정보는 HDD 등에 매주 1회 이상 백업하며 2주 이상 보관하고 있는가?
	로그의 복사본을 별도의 장소에 보관하고 있는가?
	로그는 테이프 등에 매일 1회 이상 백업하여 3개월 이상 보관하고 있는가?

	백업매체는 안전한 방법으로 폐기되고 있는가?
점검	분기별로 1회 이상 정보보안시스템을 점검하고 있는가?
	시스템 무결성 파일을 정기적으로 점검하여 변경, 교체, 삭제된 파일의 리스트를 작성하여 관리하고 있는가?
	로그분석이 제대로 수행되고 있는지 월1회 이상 감사하고 있는가?

13. 웹메일 운영 매뉴얼

구분	점검항목
웹 메일 보안	내부 정보를 외부로 송신하기 위해서는 사전에 그 타당성에 대해 해당 전결권자의 승인을 득하며 선택적으로 암호화하여 전송하고 있는가?
	e-mail 계정 신청/삭제는 e-mail 시스템 관리자에게 요청하고 있는가?
	한명의 직원이 1개의 e-mail 계정을 가지고 있는가?
	e-mail 패스워드를 주기적으로 변경하고 있는가?
	e-mail을 통한 업무자료 수발신은 내부 전자문서시스템을 사용하고 있는가?
	비정상적인 메일(대량의 스팸메일, 바이러스 첨부메일 등)을 대응하기 위해 모니터링을 하며 차단하고 있는가?
	e-mail 사용과 관련한 보안사고 인지 시 침해사고대응매뉴얼에 따라 대응하며, 관련 내용을 E-Mail 보안사고 및 대응 결과서에 기록하고 있는가?

14. 물리적 보안관리 매뉴얼

구분	점검항목
보호구역 설정	보호구역을 적절히 설정하였는가?
전산장비실 관리	출입문 상단 중앙에 통제구역의 표찰을 부착하고 있는가?
	전산장비실에 상주하는 외부인력은 신원조회를 실시하여 근무 적격 여부를 판단하고 있는가?
	전산장비실 창문은 개폐 및 분리가 안되고 있는가?
	감시 카메라 및 출입통제장치를 설치하고 있는가?
출입통제	보호구역 출입자 명부를 비치하여 출입 시마다 기록을 유지하는가?
	반출입되는 모든 가방, 서류, 기타휴대폰 정보시스템 등은 필요 시 검색할 수 있으며, 사진기, 녹음기, 비디오 장비는 반입을 불허하고 있는가?
	출입문을 항상 닫아놓고, 비인가자의 출입을 금지 하는가?
방재시스템 관리	방재시스템은 적정하며 잘 관리되고 있는가?
장비관리	대용량 착탈식 디스크, CD-ROM Writer 등과 같은 휴대용 정보시스템의 사용을 제한하고 있는가?
	장비 폐기 전에 저장매체로부터 중요한 데이터 라이선스가 있는 소프트웨어가 제거되었는지 확인하고 있는가?
자료 보안	문서는 안전하게 파지 또는 소각하고 있는가?
	주요 서류 및 이동형 저장매체를 사용하지 않을 경우 시건 장치가 있는 캐비닛이나 창고에 보관하고 있는가?(비품 등과 함께 보관되어 있는가?)
사무실 보안	사무실 정리 정돈을 적절히 수행하고 있는가?

15. 기타

구분	점검항목
업무연속성계획의 시험 및 유지관리	업무연속성계획서(재난복구대책 등)가 수립되어 있으며, 현상황에 맞게 지속적으로 업데이트 되고 있는가?
	재해 대응을 위해 주기적으로 모의훈련을 실시하고 있는가?

	재해 대응을 위해 업무연속성관리 조직이 구성되어 있고, 각 담당자들이 자신의 역할을 충분히 인지하고 있는가?
	해당 담당자나 직원들에게 업무연속성(BCP)에 대한 교육이 적절히 이루어지고 있는가?
준거성	홈페이지에서 제공하는 개인정보보호 방침 내에 개인정보보호 관리 책임자가 실제 담당자와 일치하는가?
	정보보안관련 법을 포함한 법적, 계약적 요구사항을 식별하여 대응할 수 있도록 방안을 수립하는 담당자가 지정되어 있는가?

【별표 6】

클라우드 서비스 유형에 따른 역할 및 책임

클라우드 서비스 유형	클라우드 서비스 제공자	클라우드 서비스 이용자
IaaS	1. 물리적 영역의 시설 보안 및 접근 통제 2. 호스트 OS에 대한 보안 패치 3. 하이퍼바이저 등 가상머신에 대한 보안관리 등	1. 게스트 OS, 미들웨어 및 애플리케이션 보안 패치 2. 게스트 OS, 미들웨어, 애플리케이션, 사설 네트워크 영역에 대한 보안 구성 및 설정 3. 데이터 보안 4. 관리자, 사용자 권한 관리 등
PaaS	1. IaaS 영역에서 클라우드 서비스 제공자의 역할 및 책임 2. 네트워크 영역의 보안 설정 3. 게스트 OS 및 미들웨어 영역에 대한 보안 패치, 보안 구성 및 설정	1. 애플리케이션 보안 패치 및 보안 설정 2. 데이터 보안 3. 관리자, 사용자 권한관리 등
SaaS	1. IaaS, PaaS 영역에서 클라우드 서비스 제공자의 역할 및 책임 2. 애플리케이션 보안 패치 및 보안설정 3. 데이터 보안(데이터 레벨의 접근통제, 암호화 등) 등	1. 애플리케이션 관리자, 사용자 권한 관리 등

【별지 제1호 서식】 정보보안업무 추진계획

정보보안업무 추진계획

1. 활동 목표
2. 기본방침
3. 세부 추진계획

분야별	사업명	세부 추진계획	주관·관련부 서	비고

※ 보안성검토 대상여부 표기

4. 전년도 보안감사·지도방문 시 도출내용과 조치내역

도출내용	조치내역	담당부서

※ 형식위주의 계획수립을 지양하고 소속기관의 추진계획을 종합, 자체 실정에 맞게 작성

【별지 제2호 서식】 정보보안업무 심사분석

정보보안업무 심사분석

1. 총평
2. 주요성과 및 추진사항
3. 세부 사업별 실적 분석

추진계획	추진실적	문제점	개선대책

※ 추진실적은 목표량과 대비하여 성과 달성도를 계량화

4. 부진(미전)사업

부진사업	원인 및 이유	익년도 추진계획

5. 애로 및 건의 사항
6. 첨부(정보통신망 및 정보보안시스템 운용현황 등)

【별지 제3호 서식】 정보자산 목록

정보자산 목록

부서 명: 000

정보자산 관리자(부서장): 000

정보자산 담당자: 000

[illegible]

【별지 제4호 서식】 정보보안 서약서(교직원용)

정 보 보 안 서 약 서(교직원용)

■ 기 관 :

■ 부서(팀)명 :

■ 직책 및 직급 :

■ 성 명 :

본인은 한국기술교육대학교에 근무함에 있어서 다음 각 호의 정보보안사항을 충분히 숙지하고, 성실히 준수할 것을 서약합니다.

1. 본인은 한국기술교육대학교의 정보보호 관련 규정 및 규칙, 관련 매뉴얼을 준수하여, 보안 사고가 발생되지 않도록 예방 및 주의에 최선을 다할 것입니다.
2. 본인은 한국기술교육대학교에 근무하는 동안 취득한 대학의 정보, 개인정보, 지적 재산권들을 엄격히 보호할 것이며, 이를 개인적인 용도나 제 3자를 위한 정보로 이용하지 않고 맡은 바 업무 수행을 위해서만 사용할 것입니다. 또한, 이러한 정보를 타인에게 누설하지 않을 것입니다.
3. 본인은 한국기술교육대학교의 정보자산(문서서류, 전자파일, 저장매체, 전산망, 전산장비 등)을 무단변조, 훼손, 분실 등으로부터 안전하게 사용하고 관리할 것이며, 불법적인 목적으로 사용하지 않을 것입니다.
4. 본인은 한국기술교육대학교의 업무 수행 과정 중 사용하는 PC에 승인 받은 정품 소프트웨어만을 사용할 것이며, 불법 소프트웨어 사용으로 인한 모든 책임은 본인에게 있음에 동의합니다.
5. 본인은 상기 사항을 숙지하고 이를 성실히 준수할 것을 동의하며, 본 서약서의 준수사항을 위반한 경우에는 관련 법령에 의한 일체의 민·형사상의 책임 이외에도, 한국기술교육대학교에 끼친 손해에 대해 지체 없이 변상·복구 할 것을 서약합니다.

가. 국가보안법 제4조 제1항 제2호 및 5호(국가기밀누설 등)

나. 형법 제98조, 제99조, 제113조 및 제127조 등 보안 관련 법규

년 월 일

서약인

(인)

한 국 기 술 교 육 대 학 교 귀중

【별지 제5호 서식】 보호지역 출입자 통제대장

보호지역출입자통제대장

[illegible]

【별지 제6호 서식】 반입·반출 관리대장(전산장비실)

반입 · 반출 관리대장(전산장비실)

〈부서: 관리책임자: 〉

번호	반입 · 반출명	반입 · 반출처	반입 · 반출		반입 · 반출자		반입 · 반출 사유	반입 · 반출 일자	확인
			반입	반출	소속	이름			
2023-001	홈페이지서버	전산장비실		0	정보화운영팀	홍길동	폐기	2023.04.05.	

【별지 제7호 서식】 보조기억매체(전산장비 포함) 반출·입 대장

보조기억매체(전산장비 포함) 반출 · 입 대장

<부서: 관리책임자: >

장비명	관리번호 (시리얼번호)	사용자	용도	반출입 기간			
				반출(시작)	확인	반입(종료)	확인
노트북	0602058 (500920720008)	홍길동	교무 업무	2010.10.18 08:30	이순신	2010.10.19 18:00	(예시)

【별지 제8호 서식】 보안서약서(외부자용)

보안서약서(외부자용)

■ 소속 :

■ 직책 및 직급 :

■ 성명 :

본인은 20 년 월 일부로 을(를) 수행함에 있어 다음 사항을 준수할 것을
엄숙히 서약합니다.

1. 본 사업 추진의 사실, 그 성과 및 본 사업을 수행하는 과정에서 알 수 있는 비밀에 대해 외부는 물론 본교의 직원이라고 하여도 본 사업에 직접 관여하지 않는 자에 대해서는 공개 또는 누설하지 않으며, 사업 수행 중은 물론 종료 후에도 자신 또는 제3자를 위하여 사용하지 않겠습니다.
2. 본 사업 추진의 사실 및 그 성과가 본교에 의하여 적법하게 공개된 경우라고 하여도 미공개 부문에 대해서는 비밀을 유지하겠습니다.
3. 본 사업이 완료되거나 사업 진행 중에 어떠한 사유로든 본인이 본 사업을 수행할 수 없게 된 경우, 그 시점에서 본인이 보유하고 있는 기밀사항을 포함한 관련 자료를 즉시 본교에 반납하고 비밀을 유지하겠습니다.
4. 상기 보안 서약 미준수 시 관계법규에 따라 엄중한 처벌을 받을 것을 서약합니다.

가. 국가보안법 제4조 제1항 제2호 및 5호(국가기밀누설 등)

나. 형법 제98조, 제99조, 제113조 및 제127조 등 보안 관련 법규

년 월 일

서약인

(인)

한국기술교육대학교 귀중

【별지 제9호 서식】 보조기억매체 관리대장

보조기억매체 관리대장

〈부서: 관리책임자: 〉

연번	관리번호(S/N)	매체형 태	등록일자	취급자 (성명)	불용처리 일자	불용처리방법 (재사용용도)	비고(사유)

【별지 제10호 서식】 보조기억매체 점검대장

보조기억매체 점검대장

<부서: 관리책임자: >

점검일시	현 보유수량			이상 유무	점검관		비고 (서명)
	대외비	일반	인증		성명	서명	

【별지 제11호 서식】 보안규정 변경관리대장

보안규정 변경관리대장

[illegible]

【별지 제12호 서식】 침해사고 비상연락망

침해사고 비상연락망

1. 침해사고대응팀 연락망

담당업무	담당자	유선전화번호	휴대전화번호	E-mail
정보보호책임관				
정보보호담당관				

2. 팀별 분임정보보호담당관, 담당자 연락망

팀명	담당자업무	담당자	연락처(E-mail, HP, office)

3. 관련 업체 연락망

기관명	담당자	연락처(HP, office, e-mail)	비고

4. 유관 공공기관 연락망

기관명	담당자	연락처 (E-mail, Mobile, Office)	URL

【별지 제13호 서식】 침해사고 발생보고서

침해사고 발생보고서

결 재	정보보호 책임관	정보보호담당 관

발견일자		발견자	
침해사고 개요			
1) 발견시스템 : 2) 현상 : 3) 파급 영향 : 4) 협조 요청사항 : 5) 기타 :			
긴급성 여부			

긴급조치일자		긴급조치 담당자	
긴급조치내용 요약			

【별지 제14호 서식】 침해사고 처리 결과서

침해사고 처리 결과서

결 재	정보보호 책임관	정보보호담당 관

작성 일자		작성 부서		작성자	
-------	--	-------	--	-----	--

문제발생 일시	
대상시스템	
문제내용	
문제 원인	

조치시간		조 치 자	
사고원인		피해 범위	
조치내용 및 결과			
향후 대책			

【별지 제15호 서식】 열람·제공자료 관리대장

열람 · 제공자료 관리대장

용역업체 관리담당자	용역업체 관리책임자

☐ 업무(사업) 개요

- 업무(사업)명 : 00000

- 업무(사업)기간 : 20 . . . ~ 20 . . .

☐ 담당부서명(담당자명) : 정보화운영팀(홍길동)

☐ 용역업체명(담당자명) : (주)한국정보보안(나정보)

☐ 인수인계 확인

연번	자료명	인계 및 인수			자료 반납	
		인계자	인수자	월일	확인자	월일
1						
2						
3						

【별지 제16호 서식】 보안확약서

보안확약서

본인은 귀 학교법인과 계약한 사업의 수행을 완료함에 있어, 다음 각 호의 보안사항에 대한 준수 책임이 있음을 서약하며 이에 확약서를 제출합니다.

1. 본 업체는 업체 및 사업 참여자가 사업수행 중 지득한 모든 자료를 반납 및 파기하였으며, 지득한 정보에 대한 유출을 절대금지 하겠습니다.
2. 본 업체 직원의 과실은 곧 당사의 과실이며 이로 인해 발생하는 본교의 손해에 대해서는 당사에서 책임지겠습니다.
3. 본 업체는 보안사항을 위반했을 경우에 민·형사상 및 보안상의 책임과 관계법규에 의한 조치에 따를 것을 서약하오며 이에 확약서를 제출합니다.

년 월 일

서약업체(단체) 대표

소 속 :

직 급 :

성 명 : (서명)

한국기술교육대학교 총장 귀하

【별지 제17호 서식】 백업 결과 보고서

백업 결과 보고서

확	담당자	정보화운영팀장
인		

1. 작업일 :

2. 작업자 :

대상 시스템명			
백업종류	☐ 데이터 ☐ 로그 ☐ S/W		
백업내역	백업데이터항목		
	백업로그항목		
	백업S/W항목		
백업매체		보관장소	
백업결과 (이상여부)			
기타			

【별지 제18호 서식】 보호지역 상시 출입자 대장

보 호 지 역 상 시 출 입 자 대 장

연 번	상 시 출 입 자 인 적 사 항						비 고
	소 속	사 번	직 급	성 명	담당 업무	사 진	
1							
2							
3							
4							
5							
6							
7							